

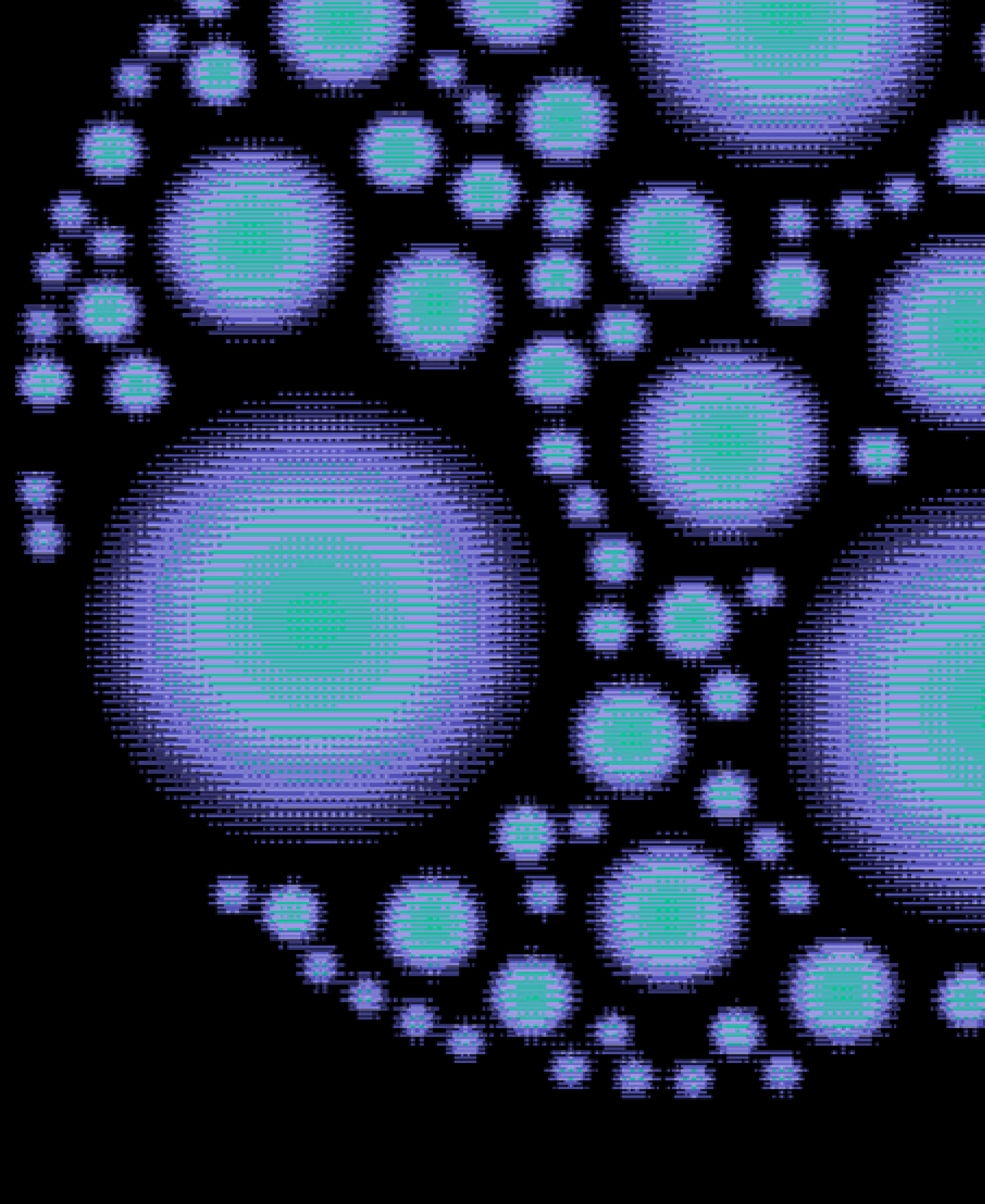


Tracking and Tackling the Wave of AI Discovered Vulnerabilities

1H-2026

Patrick Garrity

Security Researcher @ VulnCheck



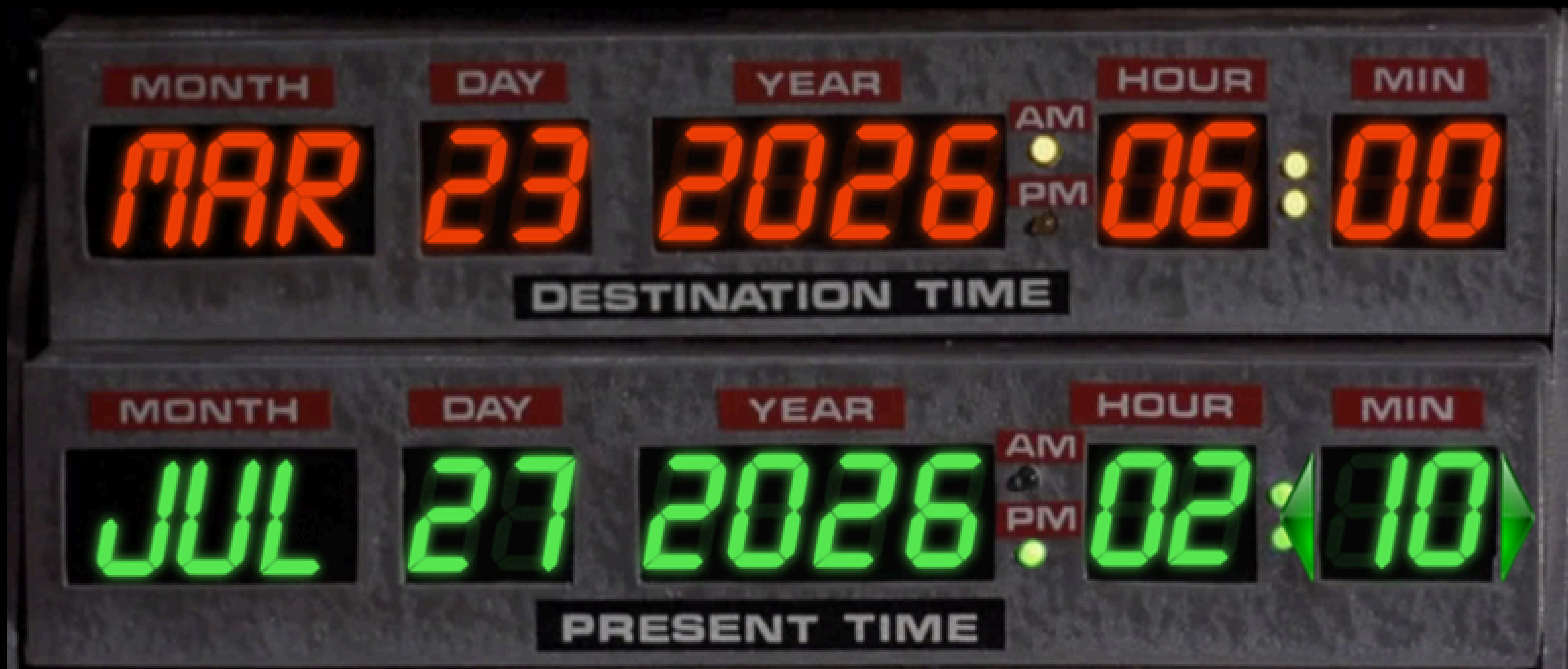
Over the past six months, we've seen a significant change in vulnerability discovery and disclosure resulting in a substantial increase in the number of CVEs disclosed.

This increase has come with warnings about the increase in vulnerability discovery by Autonomous AI systems, creating a “dangerous” scenario for the software ecosystem.

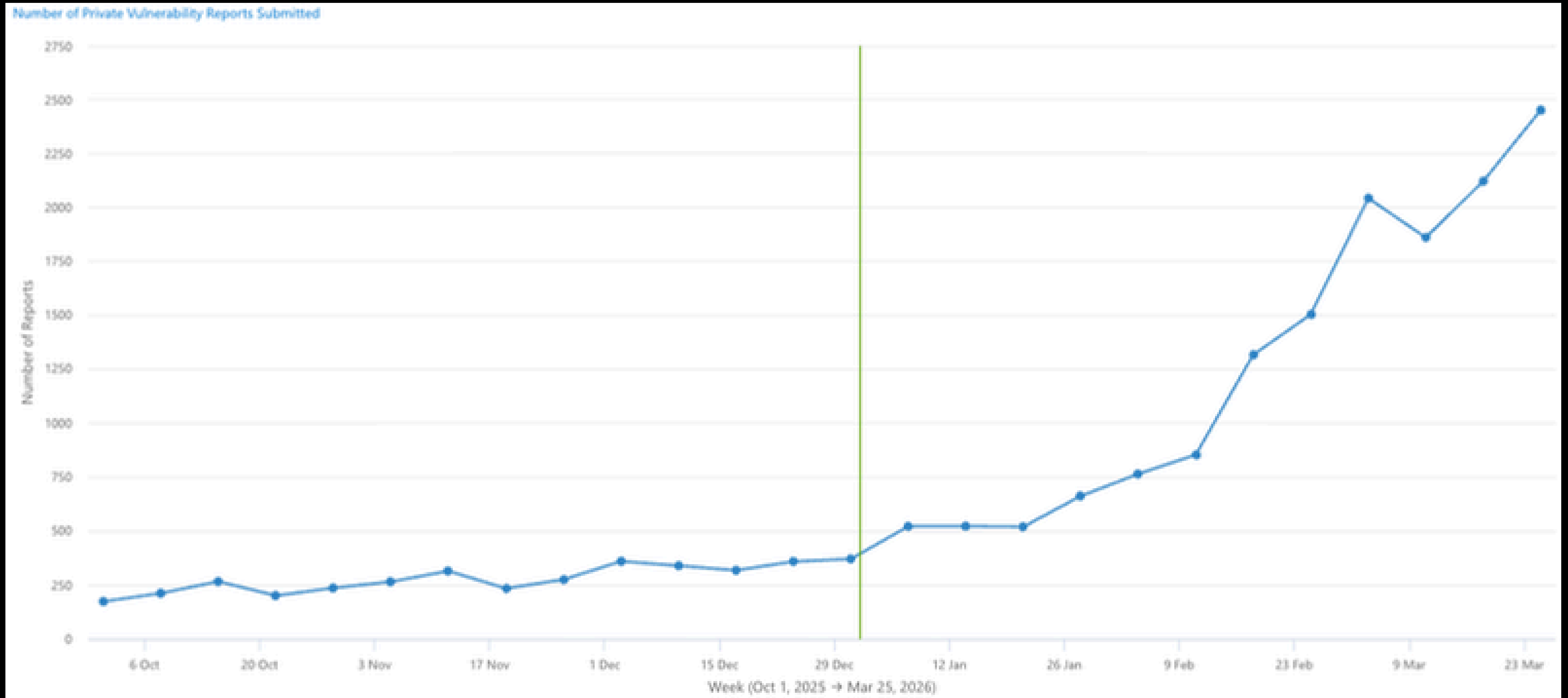
So, I was curious to explore these claims...

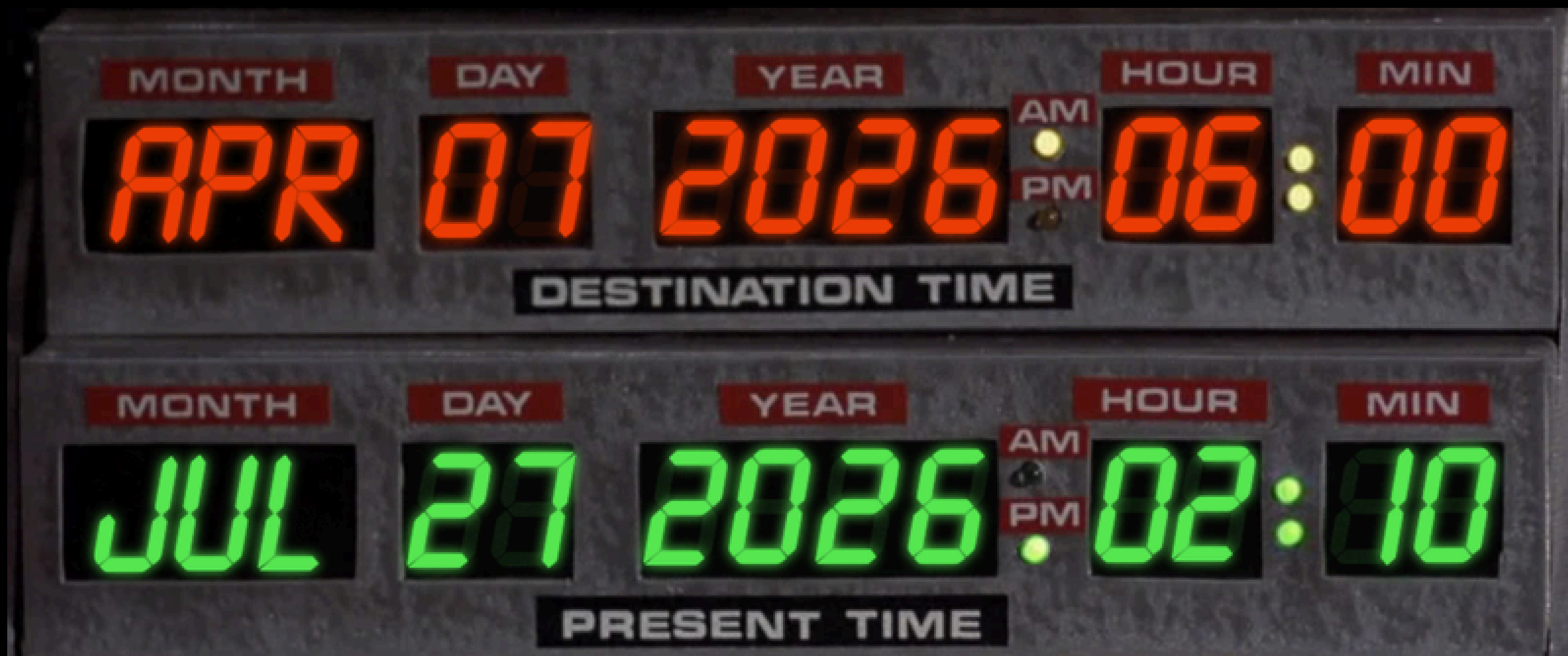
The Early Signals of AI Discovered Vulnerabilities

BACK TO THE FUTURE



Open Source - Github CVE Issuance





Project Glasswing / Mythos

What Vulnerabilities Are Directly Attributable to Glasswing?

Despite the attention around Glasswing, only one publicly disclosed CVE can currently be directly tied to it. CVE-2026-4747 (FreeBSD NFS RCE) is explicitly attributed to Glasswing and Mythos Preview by name, described as fully autonomously identified and exploited.

The Glasswing page also references three vulnerabilities without CVE numbers: a 27-year-old OpenBSD flaw, a 16-year-old FFmpeg bug, and Linux kernel privilege escalation chains. All three are still under embargo pending patches.

MONTH

DAY

YEAR

HOUR

MIN

MAY

07

2026

AM

PM

06

00

DESTINATION TIME

MONTH

DAY

YEAR

HOUR

MIN

JUL

27

2026

AM

PM

02

15

PRESENT TIME

Behind the Scenes Hardening Firefox with Claude Mythos Preview



By [Brian Grinstead](#), [Christian Holler](#), [Frederik Braun](#)

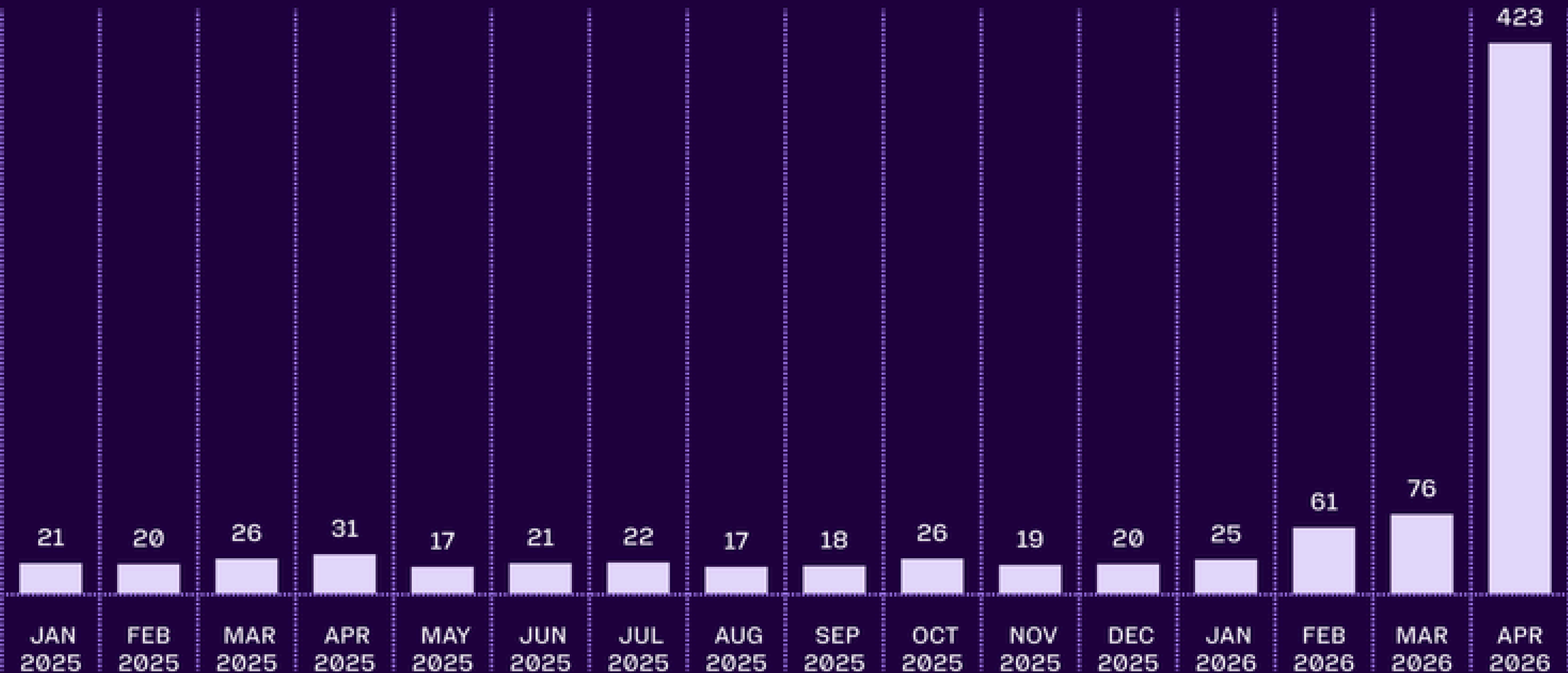
Posted on May 7, 2026, in [Featured Article](#), [Firefox](#), and [Security](#)

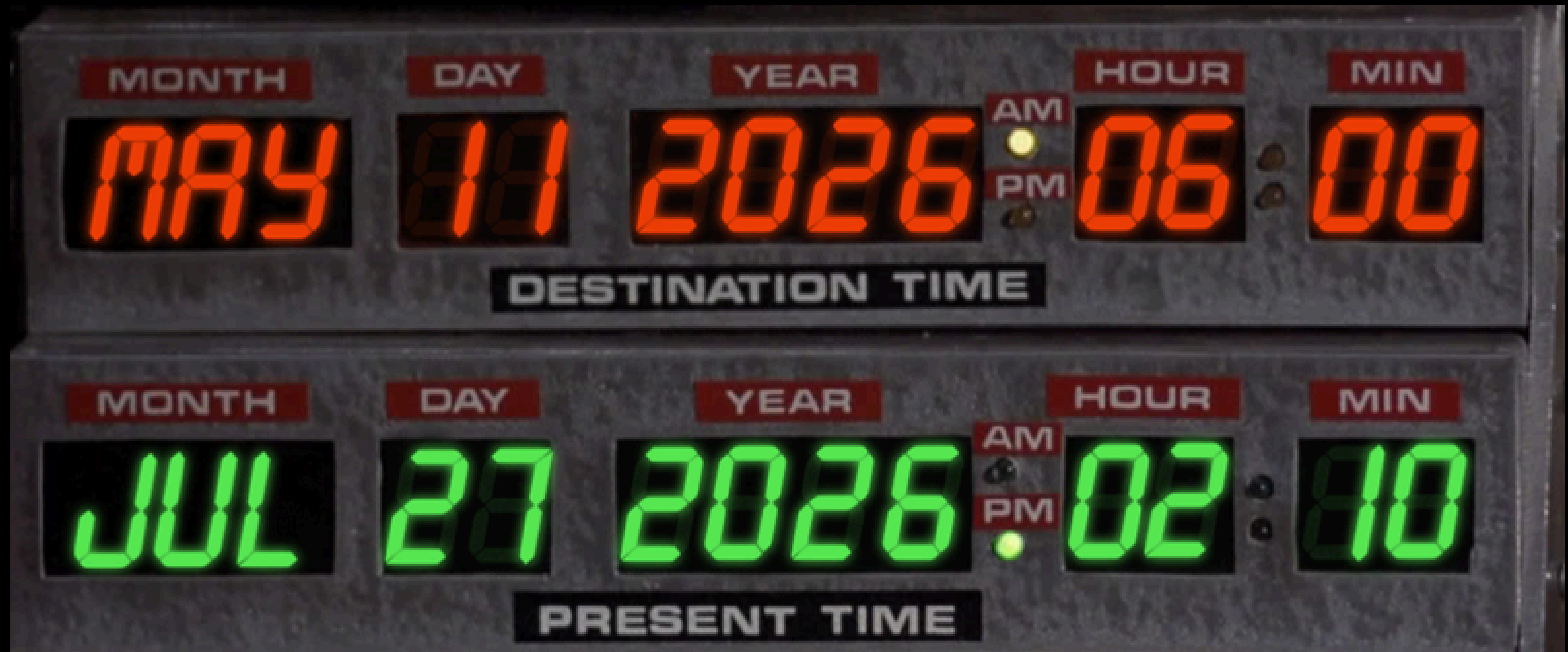
Two weeks ago we [announced](#) that we had identified and fixed an unprecedented number of latent security bugs in Firefox with the help of Claude Mythos Preview and other AI models. In this post, we'll go into more detail about how we approached this work, what we found, and advice for other projects on making good use of emerging capabilities to harden themselves against attack.

Suddenly, the bugs are very good

Firefox Security Bug Fixes by Month

All Sources • All Severities





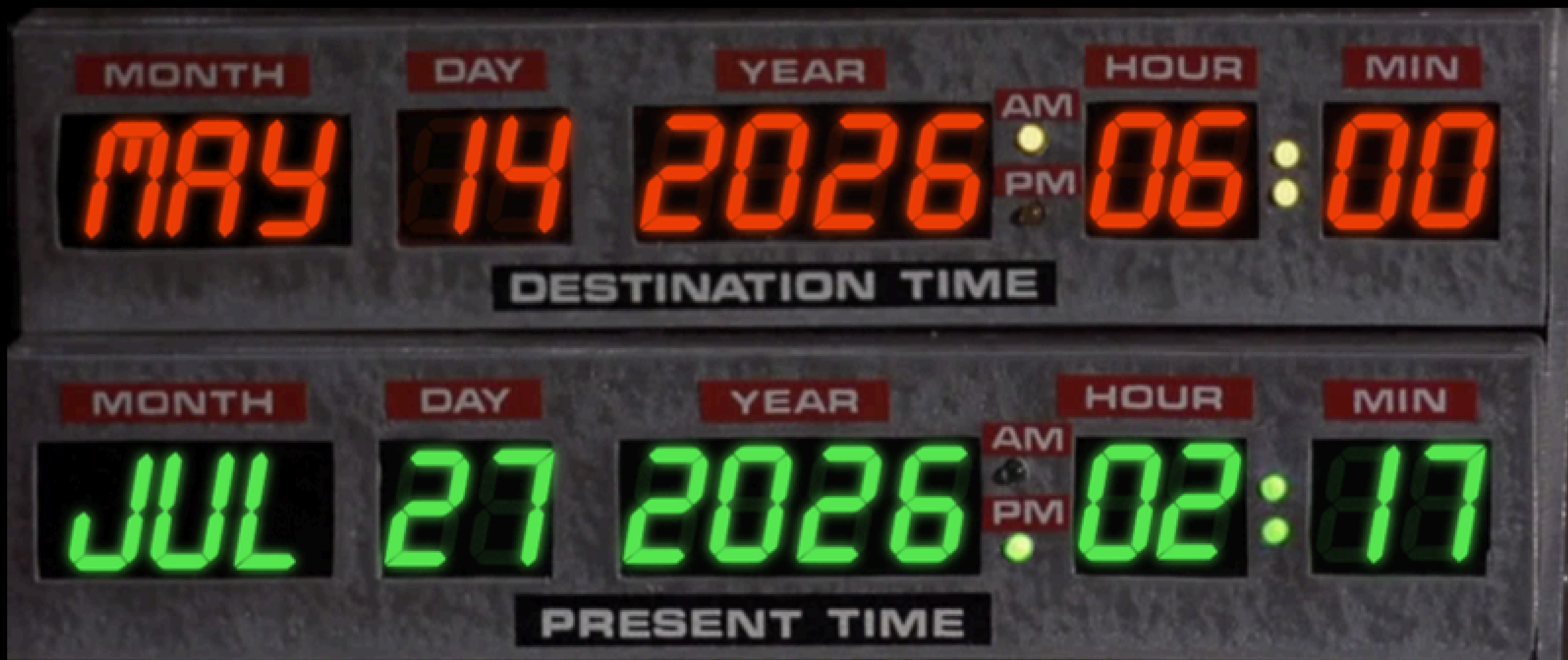


CURL AND LIBCURL, SECURITY

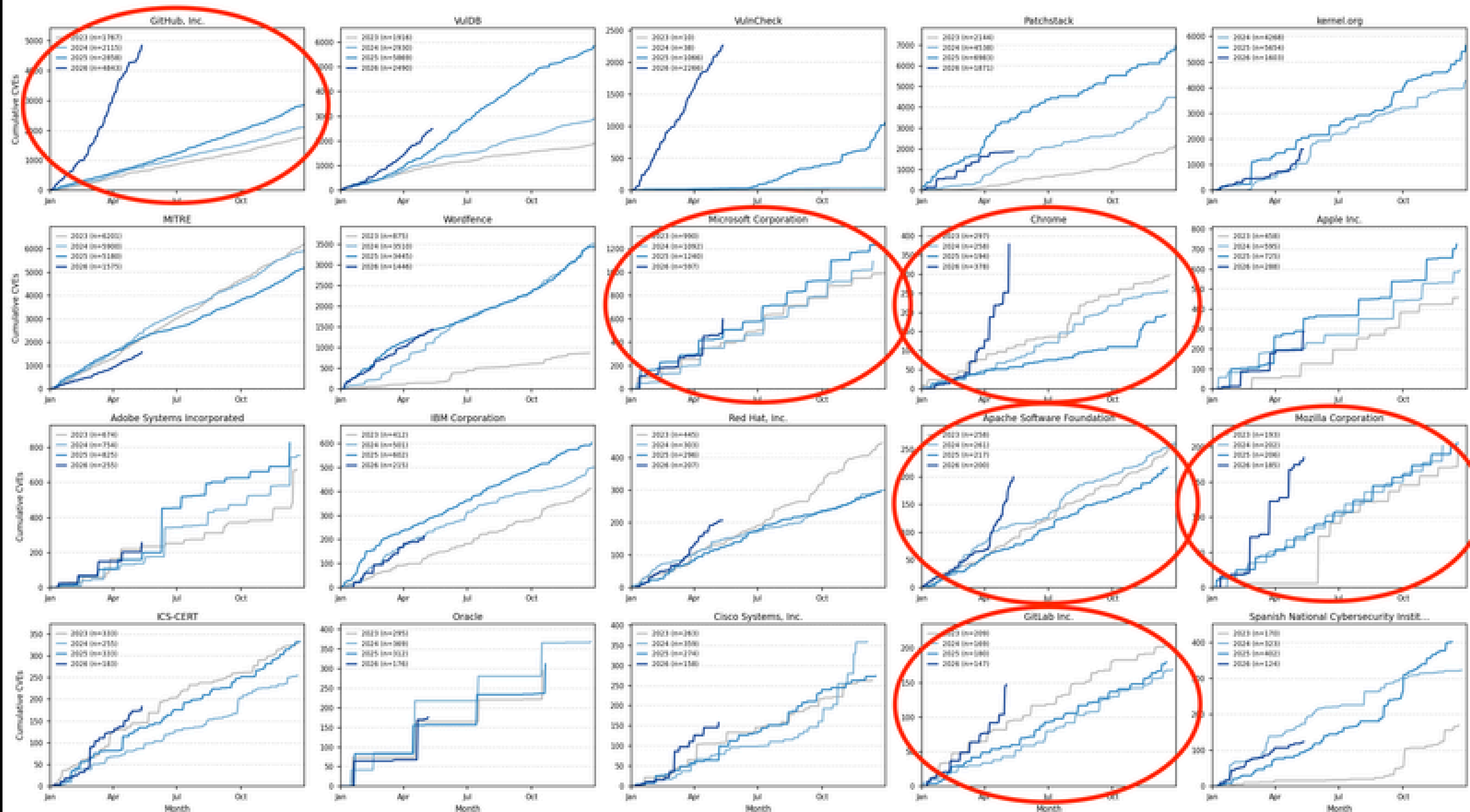
MYTHOS FINDS A CURL VULNERABILITY

🕒 MAY 11, 2026 👤 DANIEL STENBERG 💬 33 COMMENTS

yes, as in singular *one*.

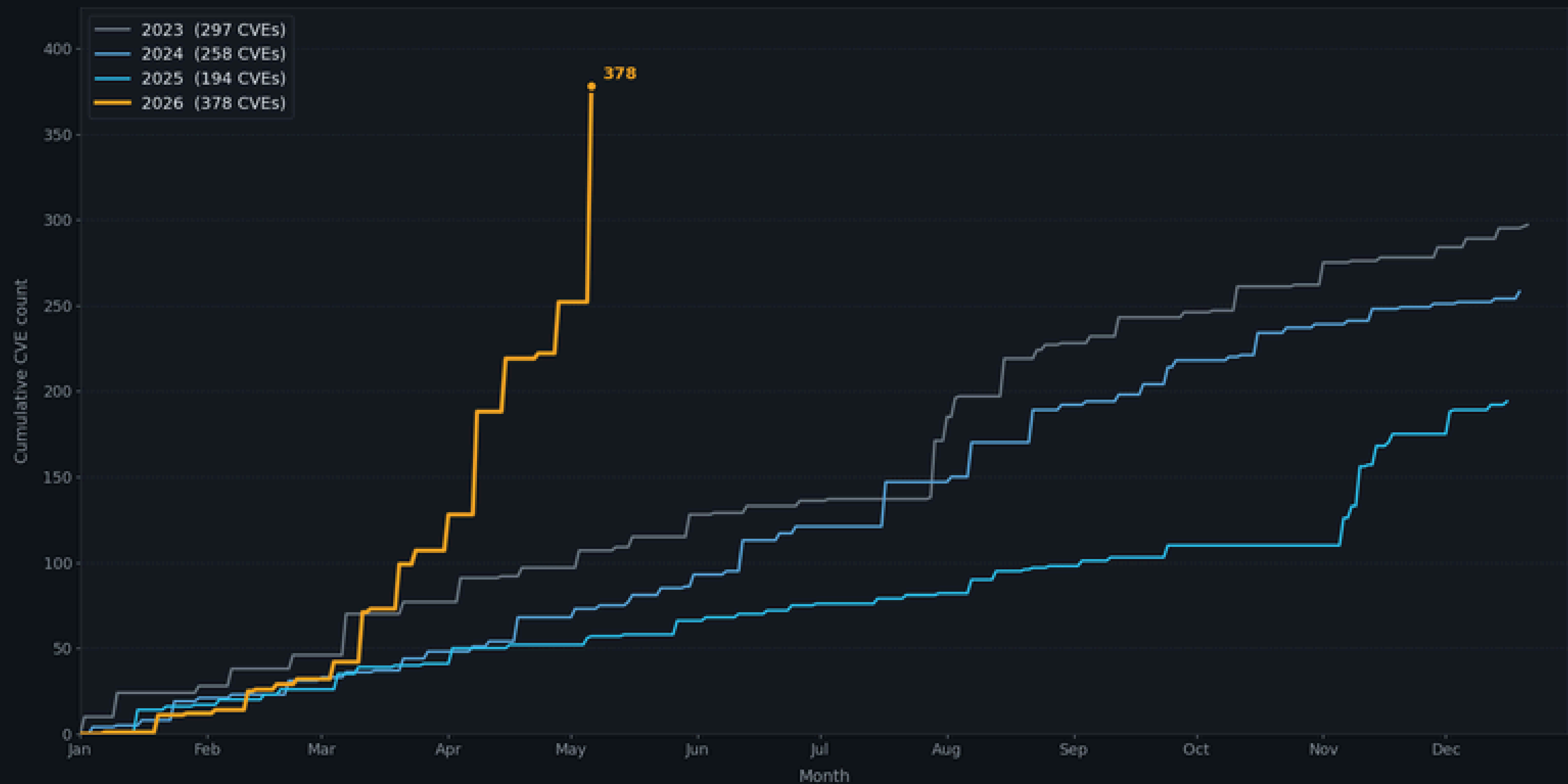


Cumulative CVE publications — top 20 CNAs by 2026 volume, 2023-2026
(y-axis scaled per panel; see legend for totals)

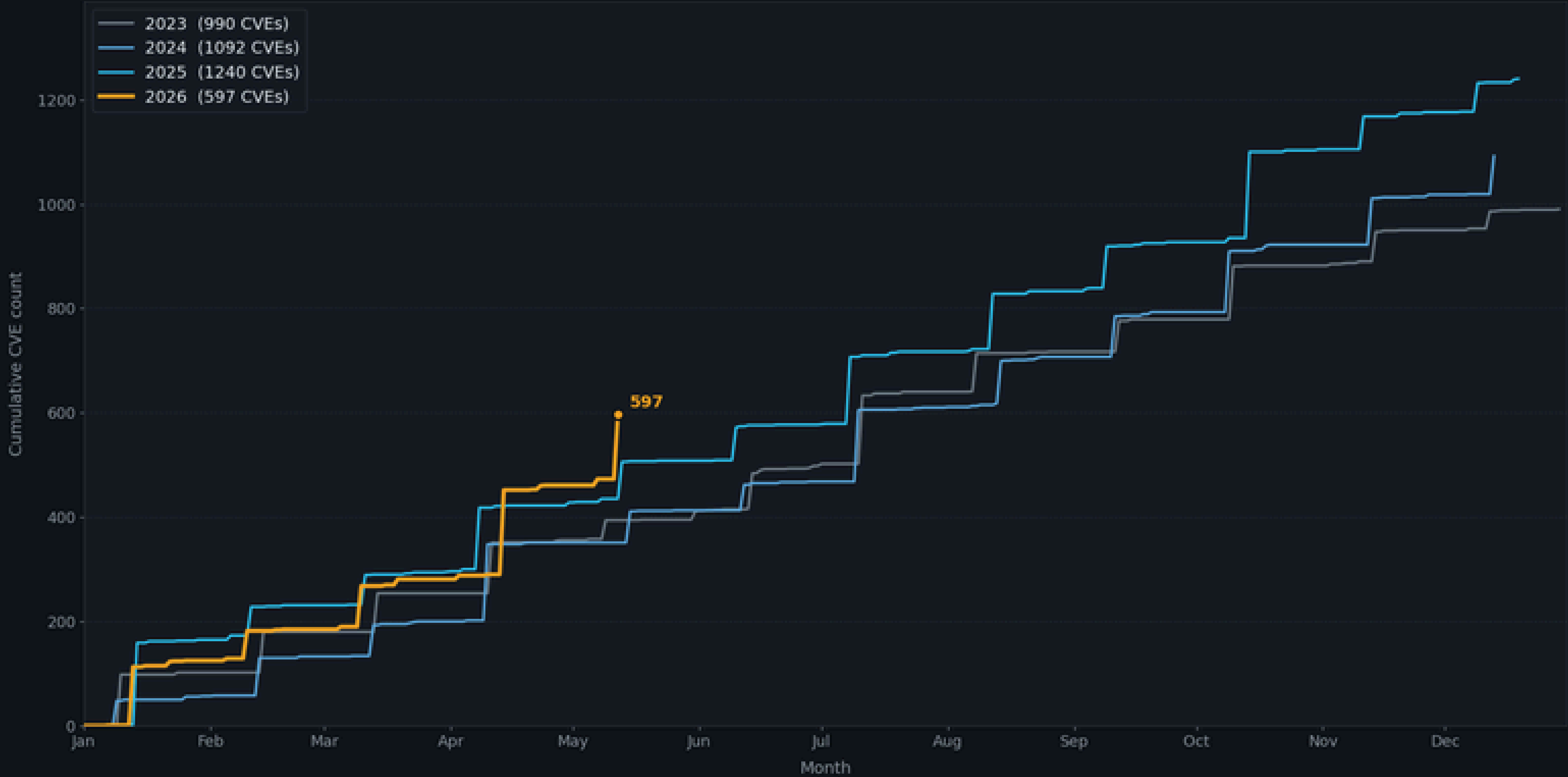


Check

Chrome 2023-2026 CVE issuance



Microsoft Corporation 2023-2026 CVE issuance



Palo Alto

While Palo Alto didn't make the charts due to lower overall CVE issuance, they've seen a 37% increase in CVE issuance year to date and have been very vocal recently about their use of frontier models. "For over a month, we've been using the latest frontier AI models, including Anthropic's Mythos and Claude Opus 4.7 and OpenAI's GPT-5.5-Cyber as part of the Trusted Access for Cyber program. Our teams have worked tirelessly to learn how to fully leverage the immense power of these models, and to find and fix any vulnerabilities as quickly as possible." - Rich Campagna, SVP Palo Alto Networks.

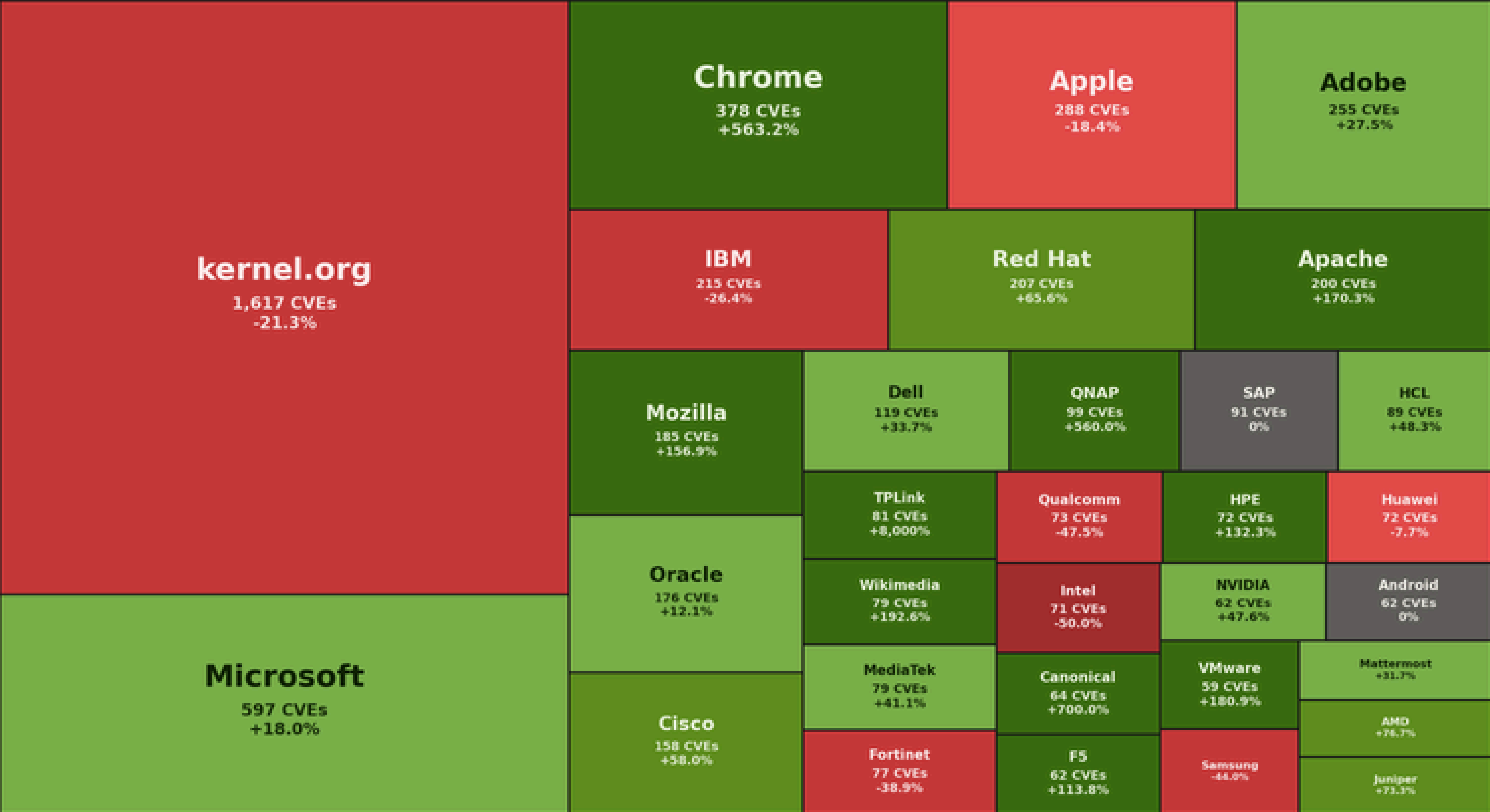
References:

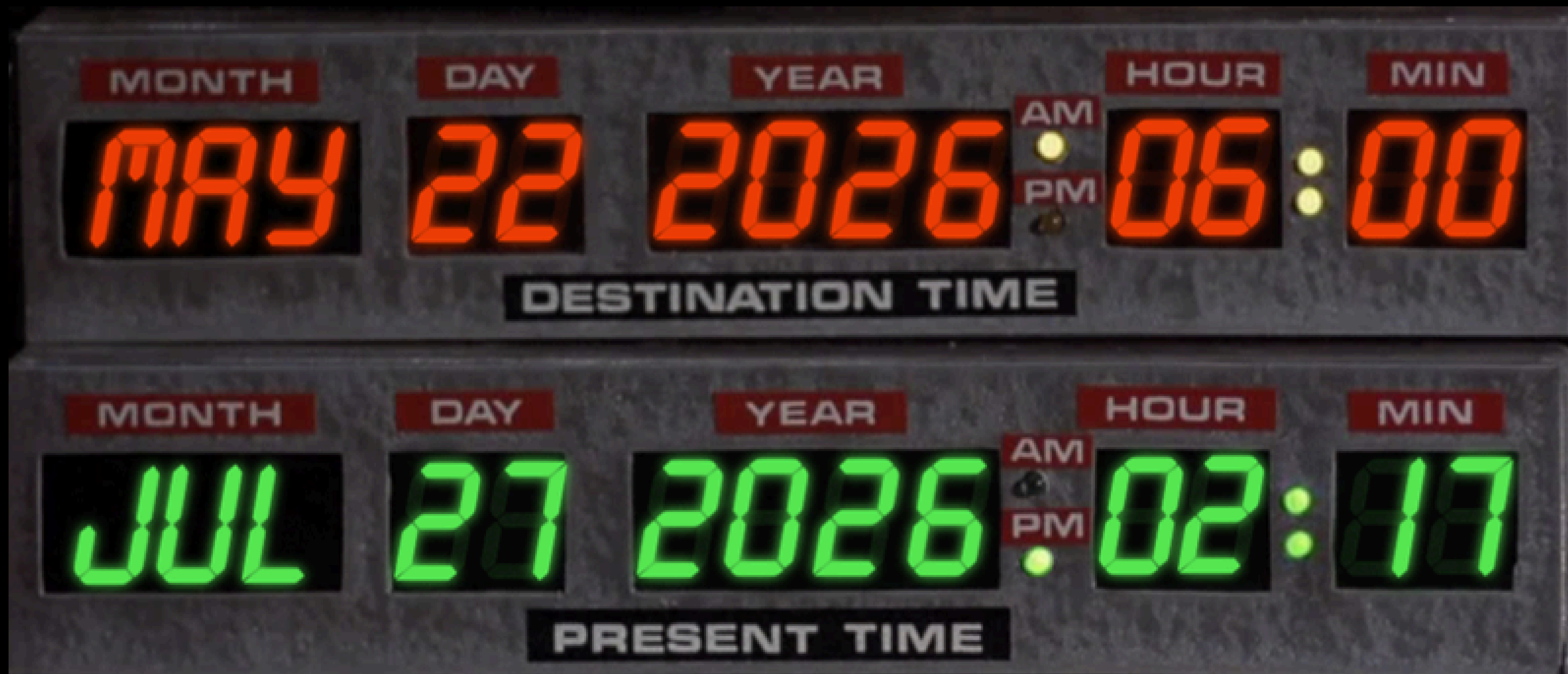
- <https://www.paloaltonetworks.com/blog/2026/05/defenders-guide-frontier-ai-impact-cybersecurity-may-2026-update/>
- https://www.linkedin.com/feed/update/urn:li:activity:7460374274588061696/?utm_source=share&utm_medium=member_desktop&rcm=ACoAAADShEQBPA7bU2zaIIHMTqDWMnEOq7PYu7g

CVE Issuance by Top Software Products

2026 YTD Growth

CVE growth % ≤ -50% -20% -1% 0% +1% +50% +100%





Disclosure ledger

[Overview](#) · [Ledger](#) · [Archive](#) · [About](#)

[Light](#) [Dark](#) [System](#)

Once a finding has been validated by one of our external security research firms, a SHA-3-512 hash of the sealed report is published immediately as proof of possession. Status is shown once the maintainer has been notified; the identifier, project, and bug class are revealed only when the disclosure window closes. Committed entries that have not yet reached the maintainer show only the hash and commitment date.

MATCHING 1,611 of 1,611 entries	DISCLOSED 1,596	FIXED 27	PRE DISCLOSURE 15	WITHDRAWN 0
--	---------------------------	--------------------	-----------------------------	-----------------------

SEARCH

hash, project, identifier, bug class...

PROJECT

All projects

BUG CLASS

All classes

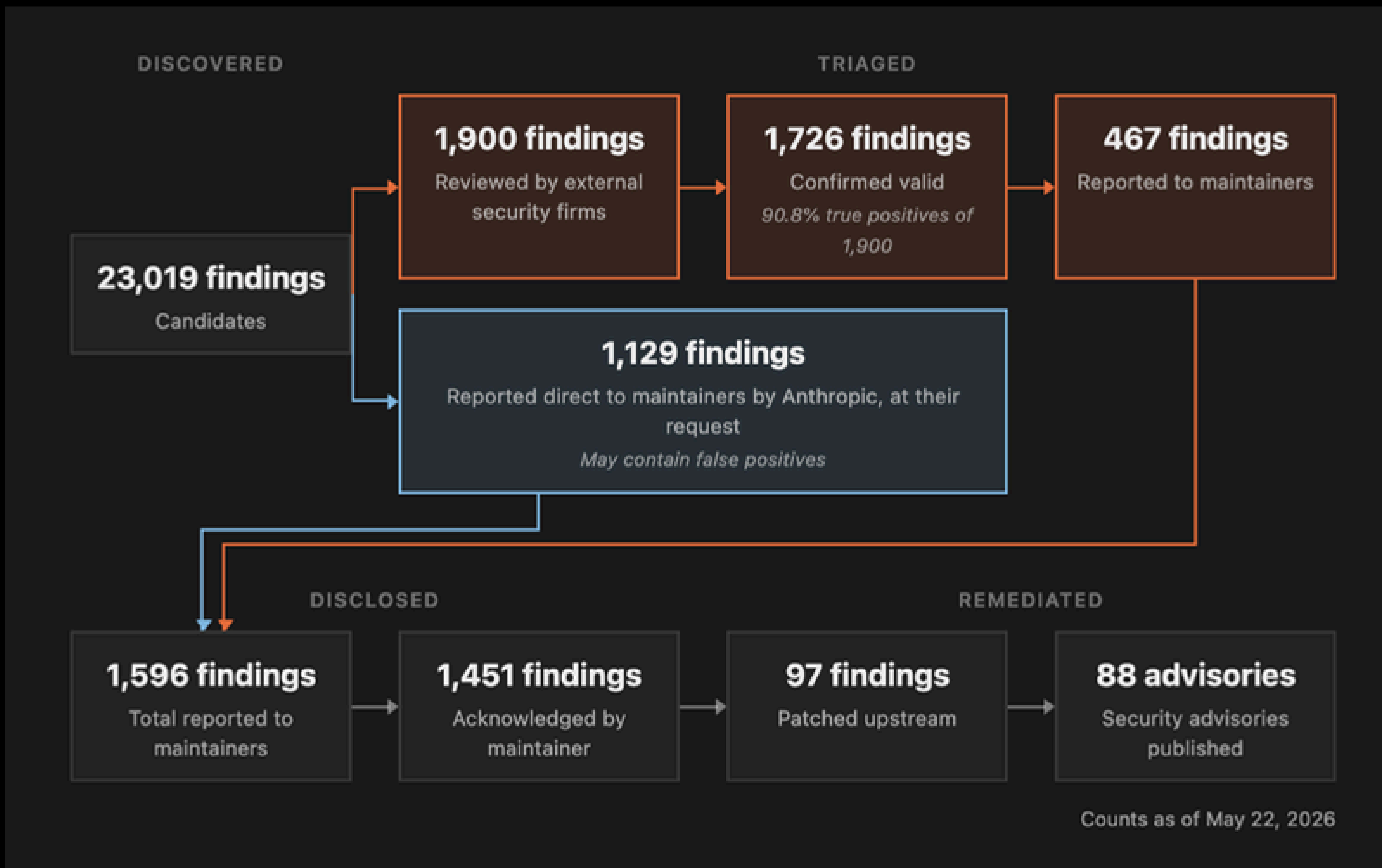
STATUS

All statuses

☐ Revealed only

Clear

DATE COMMITTED ▾	HASH / IDENTIFIER	PROJECT	BUG CLASS	STATUS
2026-05-20	c61fd338d6d28d96b01fd2b4...	—	—	DISCLOSED



External security research
firm-assessed

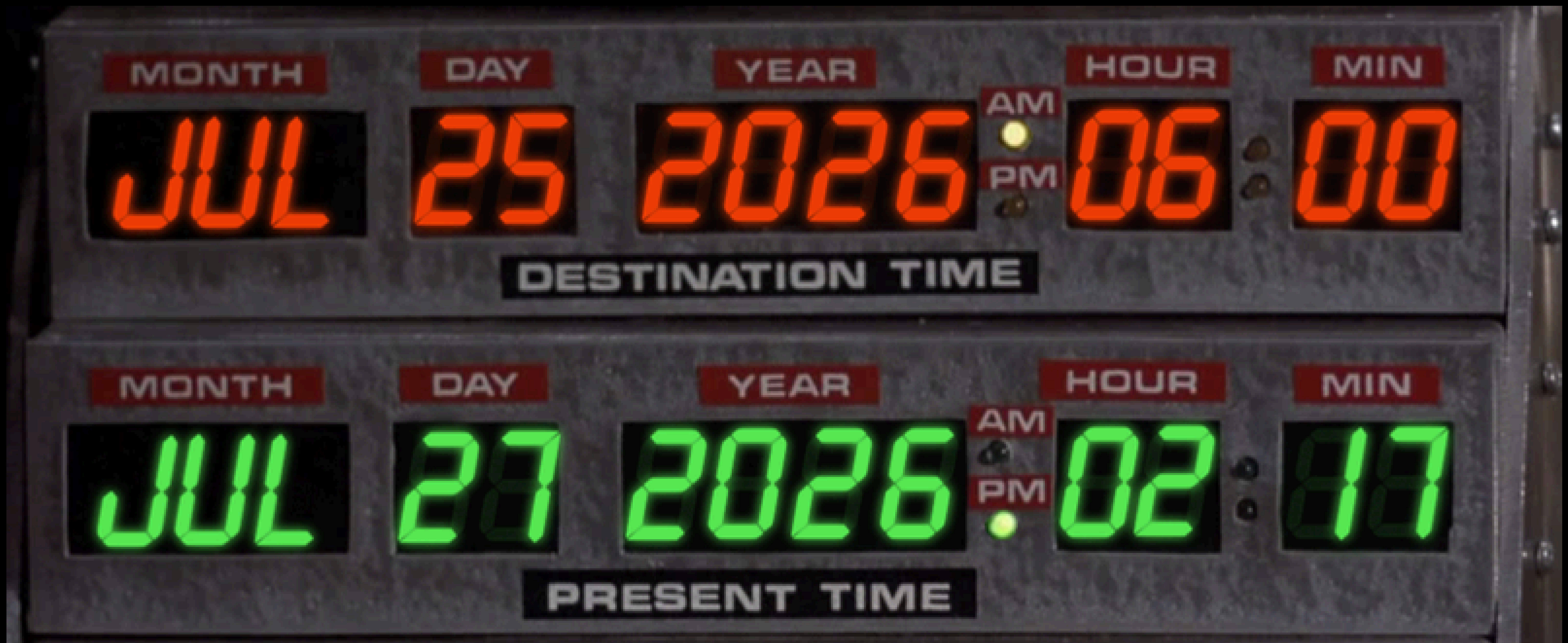
		critical	high	medium	low
Claude-assessed	critical	23	145	5	19
	high	2	180	13	2
	medium		3	52	2
	low				17

Claude-assessed (rows) against external security research firm-assessed (columns), n = 463. 58.7% exact agreement, 94.4% within one band.

Anthropic's severity assessments are produced before any maintainer input. Project maintainers often apply project-specific severity rules that Claude does not have access to at run time, so what one maintainer rates as critical another may rate as low. The external security research firms incorporate that context, which is why their assessments tend to be lower.







Disclosure ledger

[Overview](#) · [Ledger](#) · [Archive](#) · [About](#)

[Light](#) [Dark](#) [System](#)

Once a finding has been validated by one of our external security research firms, a SHA-3-512 hash of the sealed report is published immediately as proof of possession. Status is shown once the maintainer has been notified; the identifier, project, and bug class are revealed only when the disclosure window closes. Committed entries that have not yet reached the maintainer show only the hash and commitment date.

MATCHING
1,611
of 1,611 entries

DISCLOSED
1,596

FIXED
27

PRE DISCLOSURE
15

WITHDRAWN
0

SEARCH

hash, project, identifier, bug class...

PROJECT

All projects

BUG CLASS

All classes

STATUS

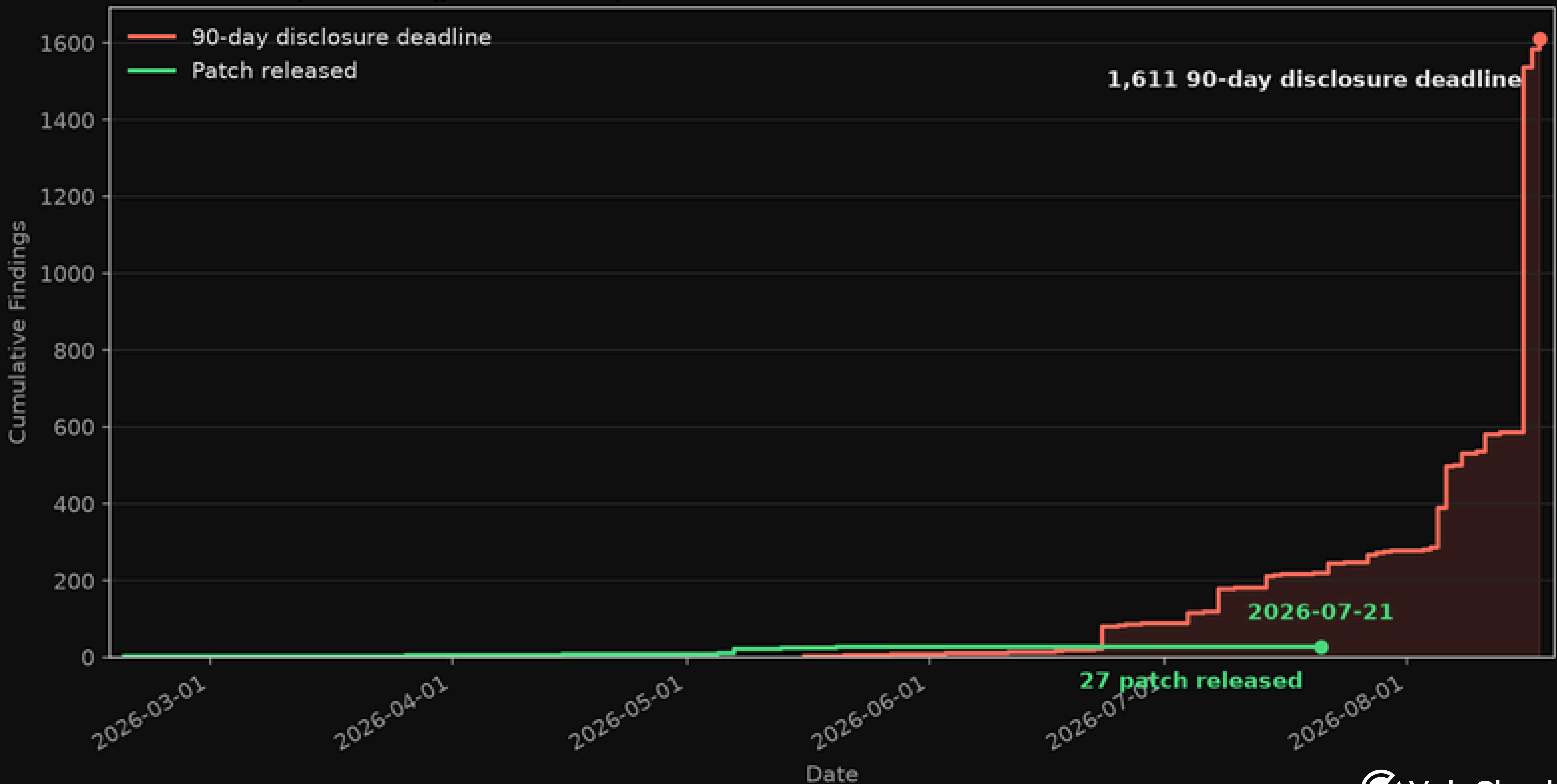
All statuses

☐ Revealed only

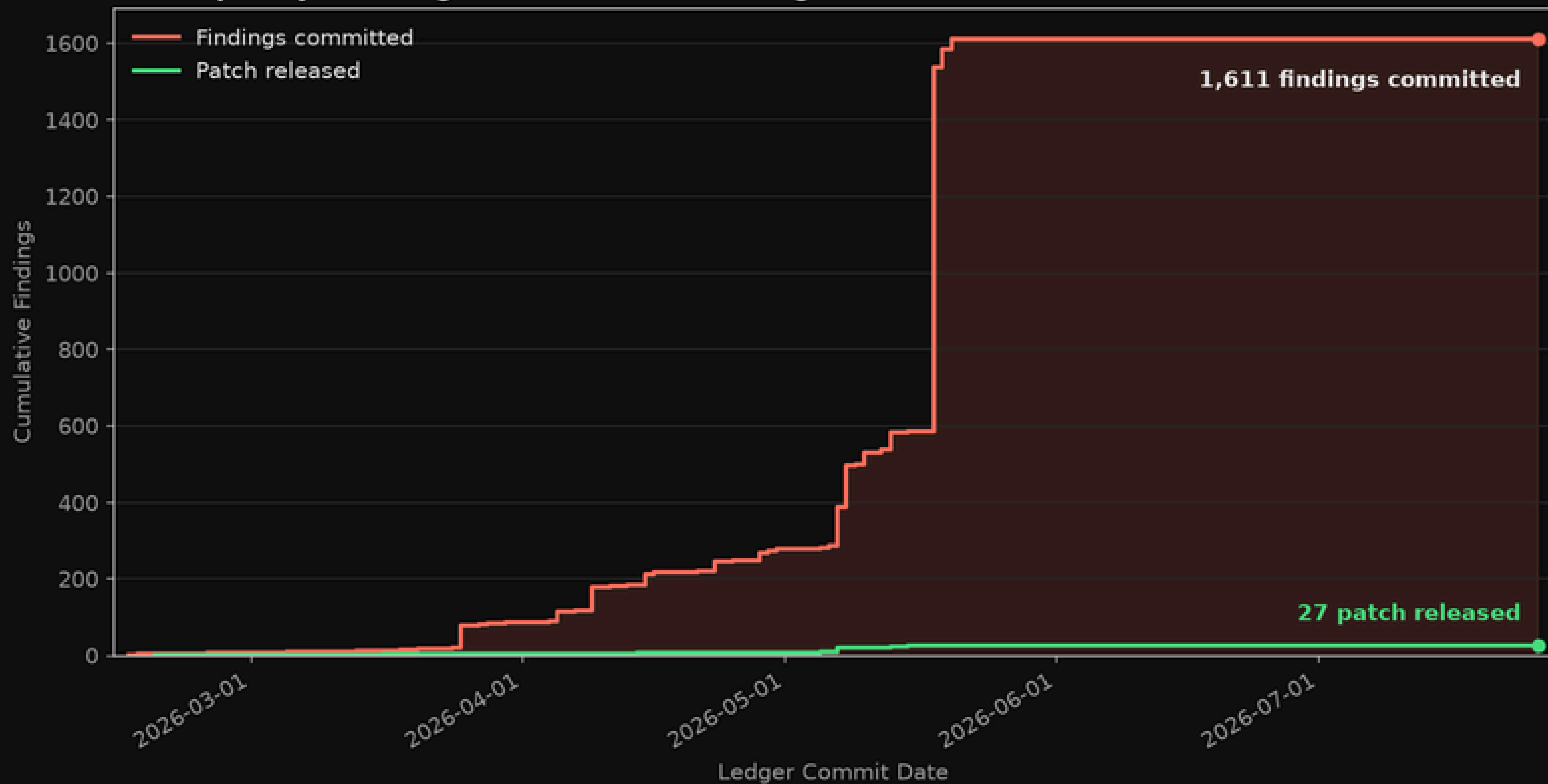
Clear

DATE COMMITTED ▾	HASH / IDENTIFIER	PROJECT	BUG CLASS	STATUS
2026-05-20	c61fd338d6d28d96b01fd2b4...	—	—	DISCLOSED

Anthropic Mythos ledger — 90-day disclosure deadline vs. patch released



Anthropic Mythos ledger — cumulative findings over time



ANTHROPIC CVE TRACKER

Overview

Tracking vulnerabilities that credit the Anthropic research team and are possibly discovered by [Project Glasswing](#).

CURRENT CVE COUNT: 133

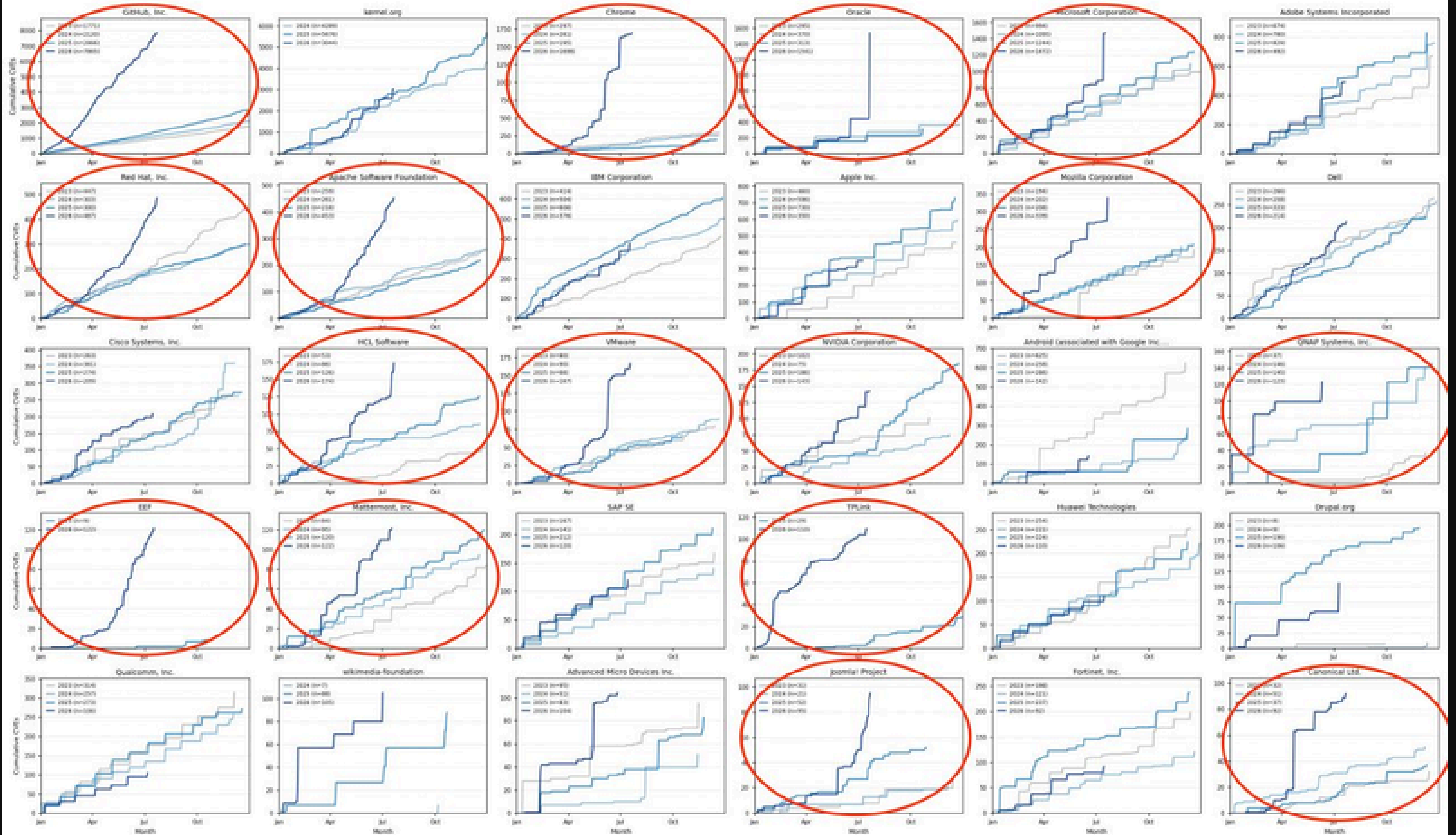
Initial Research

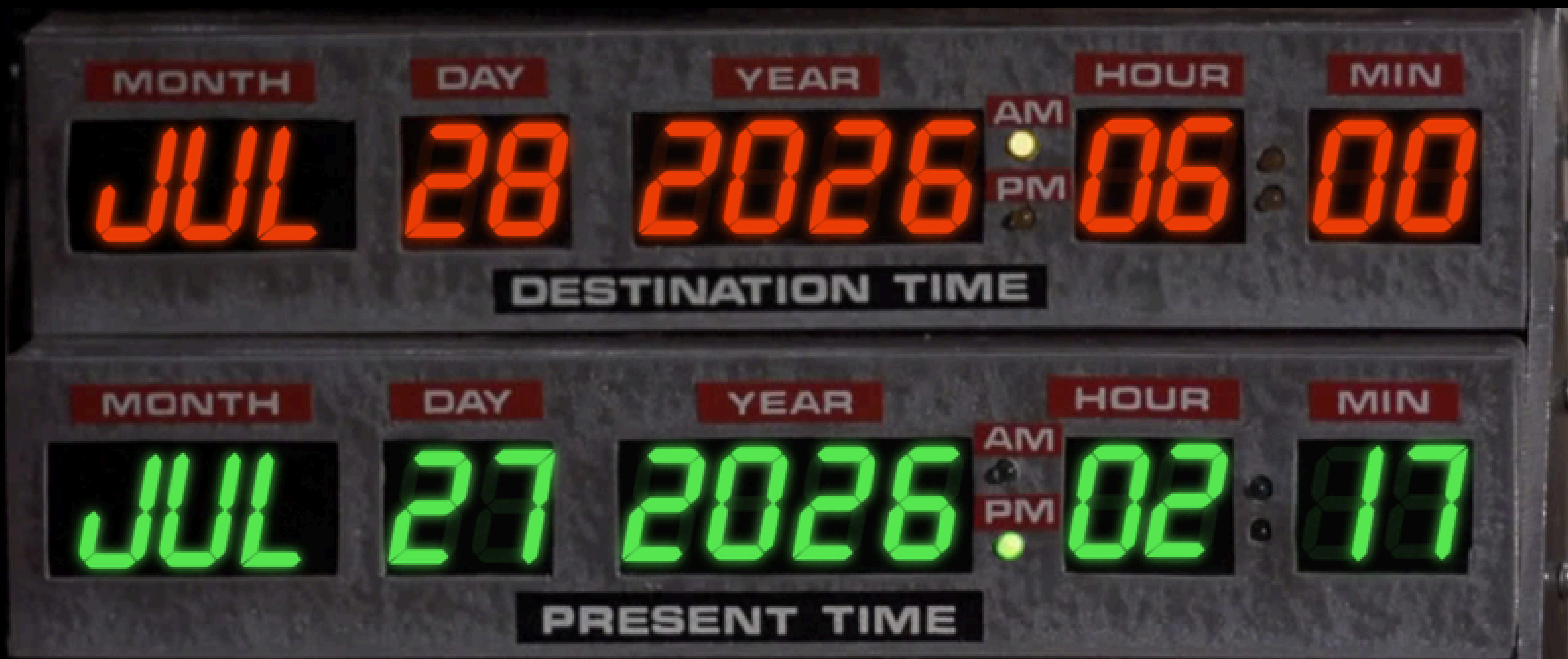
[Tracking CVEs Attributed to Anthropic Researchers and Project Glasswing](#)

Add a Vulnerability

If you find an Anthropic credited vulnerability, please open a Pull Request or Send me a message on linkedin or in the [Extended Vulnerability Community Discord](#).

Cumulative CVE publications — top 30 CNAs by 2026 volume, 2023-2026
(y-axis scaled per panel; see legend for totals)



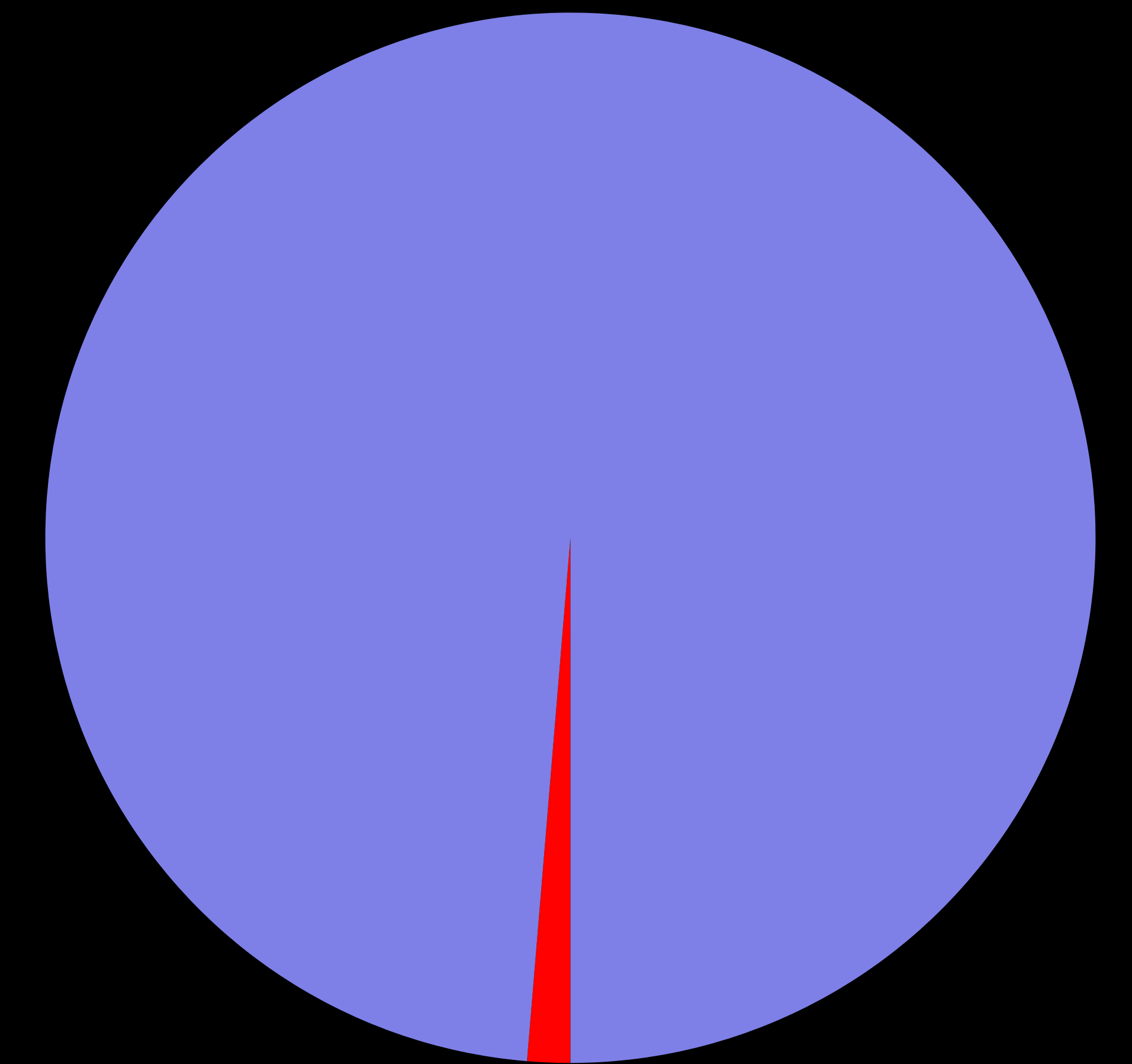
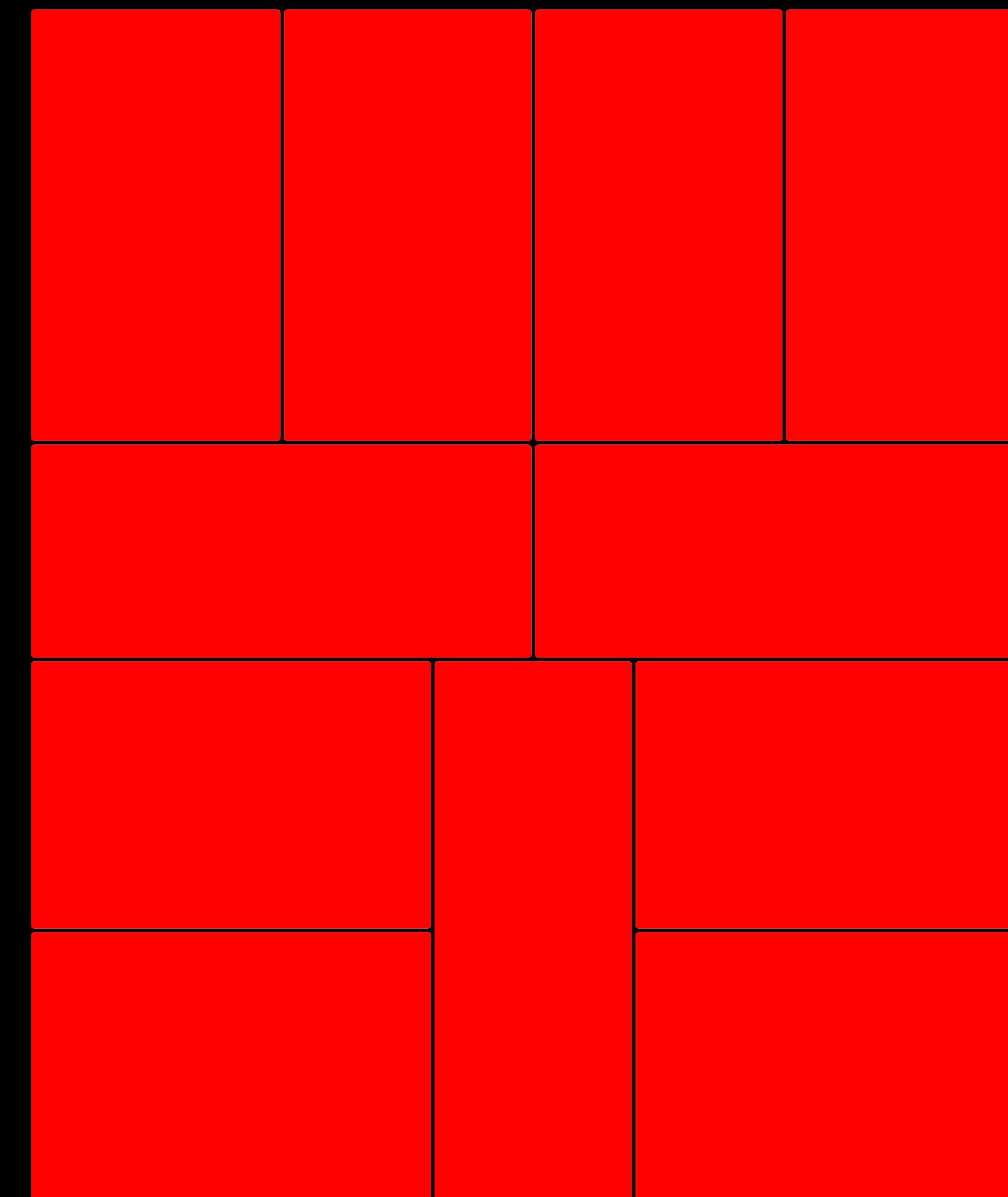


State of Exploitation

1H-2026

Patrick Garrity

Security Researcher @ VuInCheck



Are more vulnerabilities being discovered and disclosed, resulting in more vulnerabilities being exploited?

**Is the rate at which vulnerabilities are being exploited
faster?**

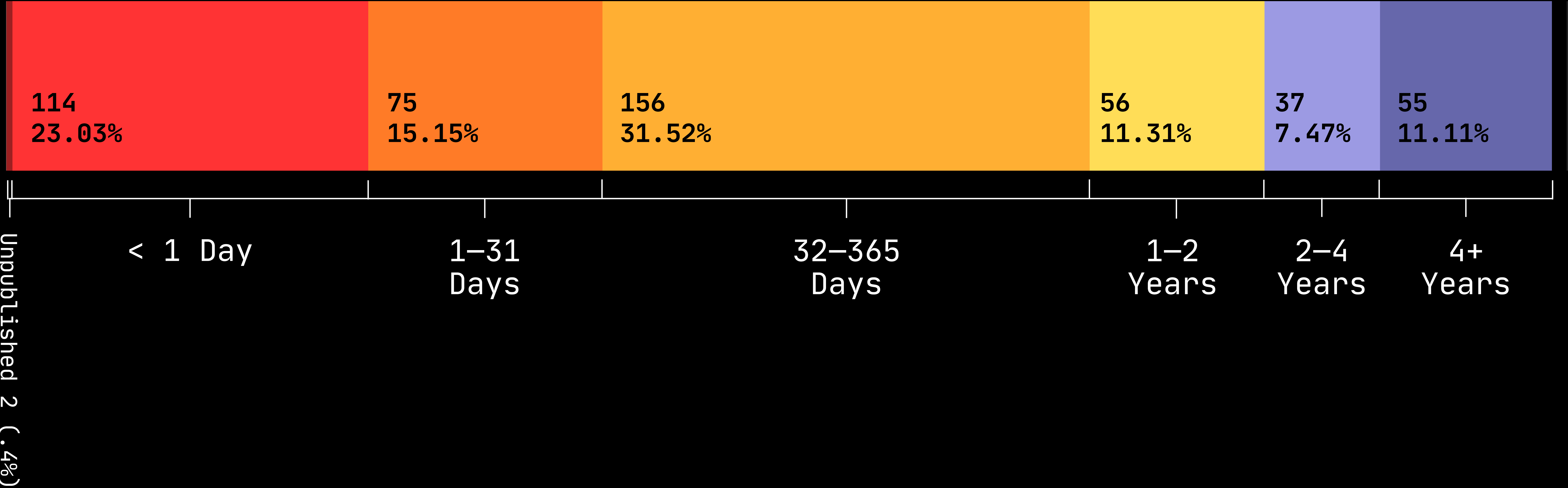
Are vulnerabilities being discovered with AI tools more dangerous?

**Or are we all feeding into the AI-Assisted vulnerability
discovery hype cycle?**

Known Exploited Vulnerabilities

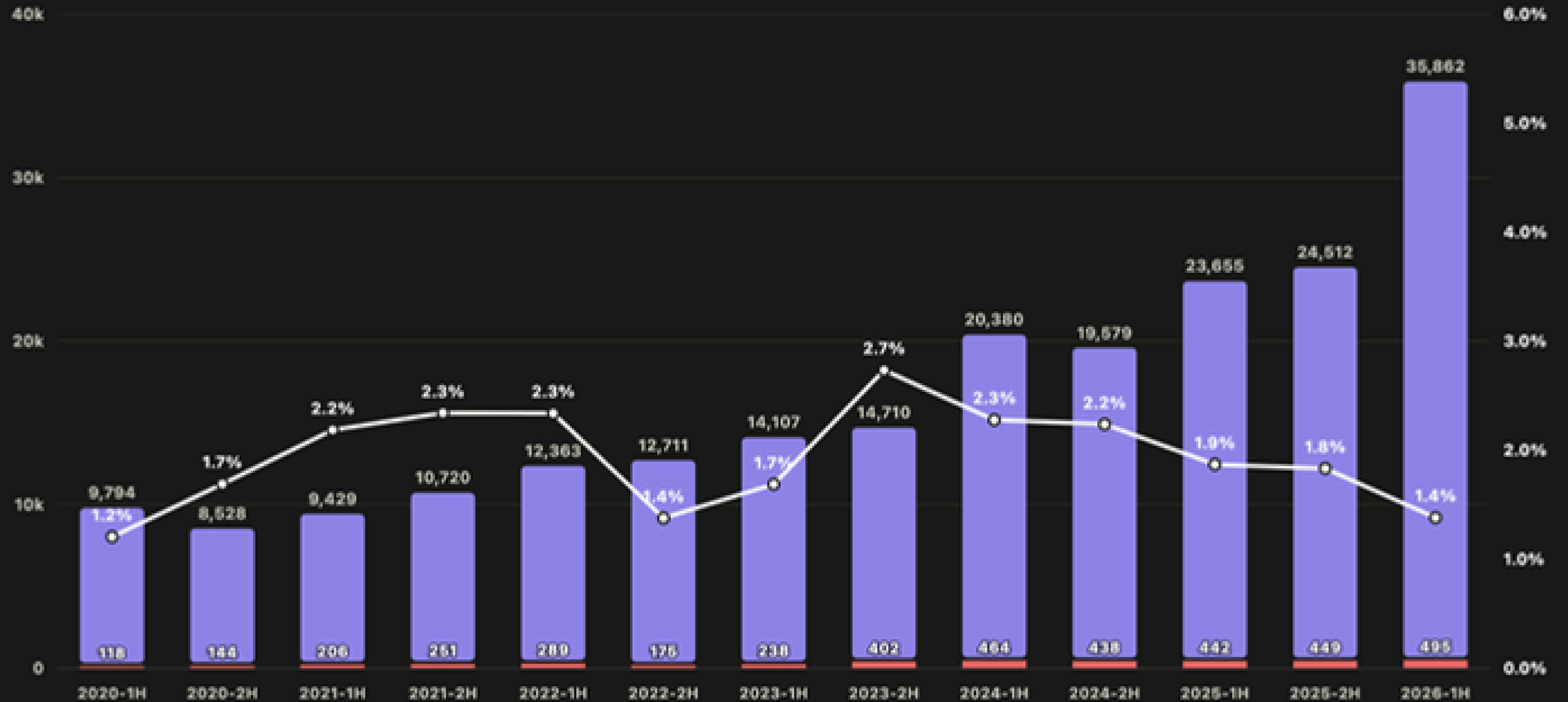
Time From CVE to Exploitation Evidence

Source: VulnCheck KEV 2026

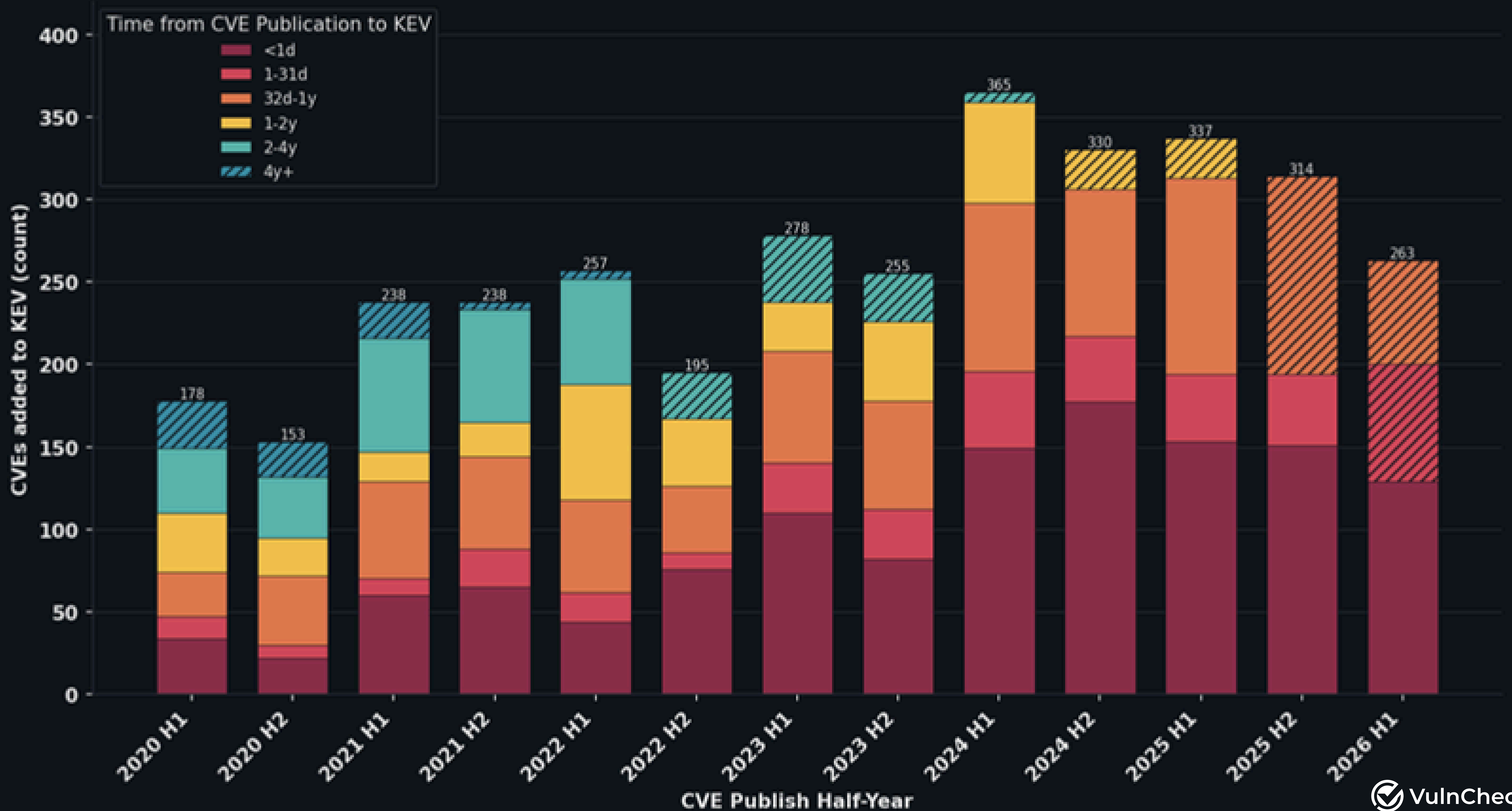


CVE Volume, KEVs, & KEV/CVE Ratio

■ CVE's Published ■ KEV's — KEV/CVE Ratio

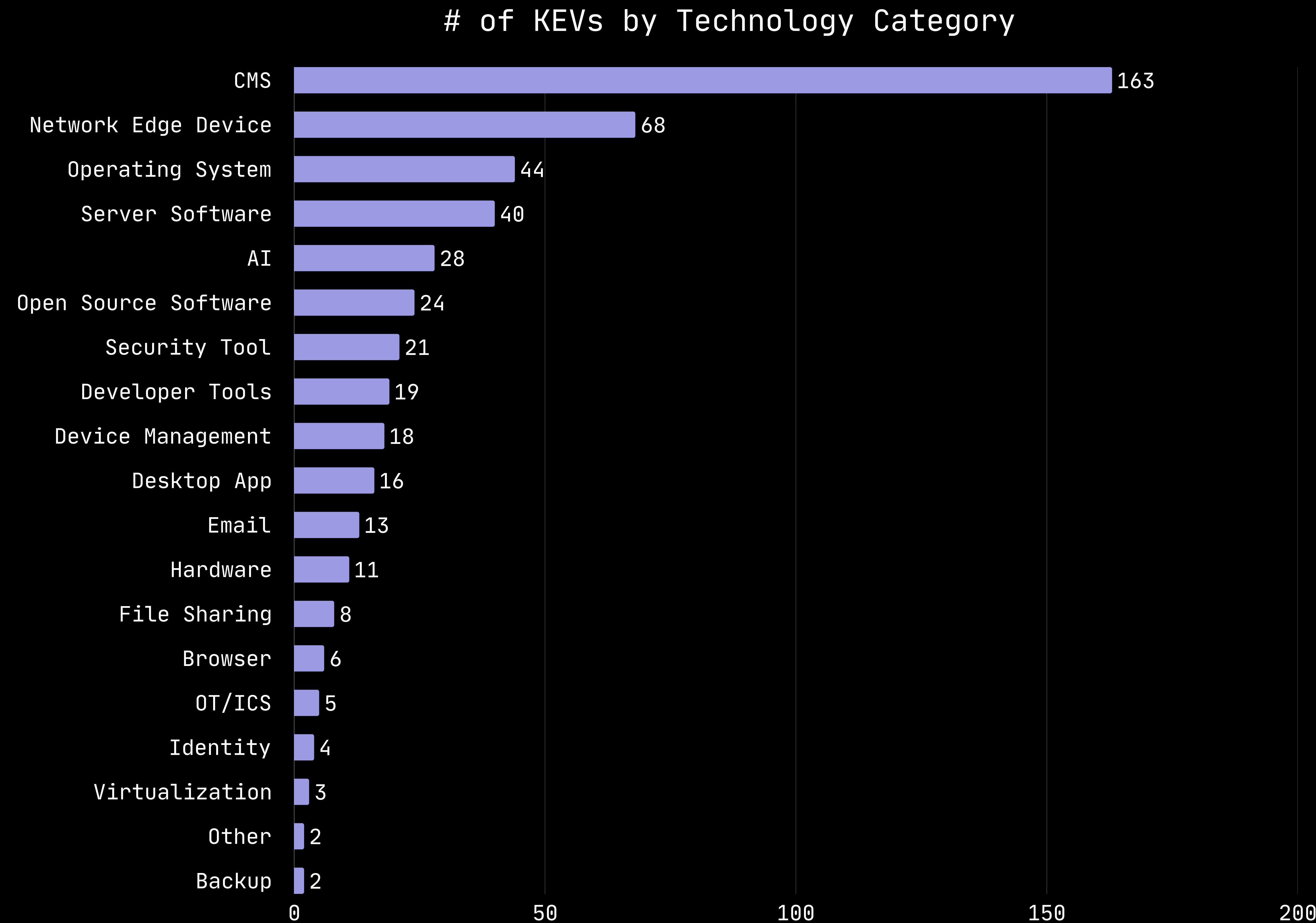


Exploitation Timeline Based on CVE Publish-Date Cohorts



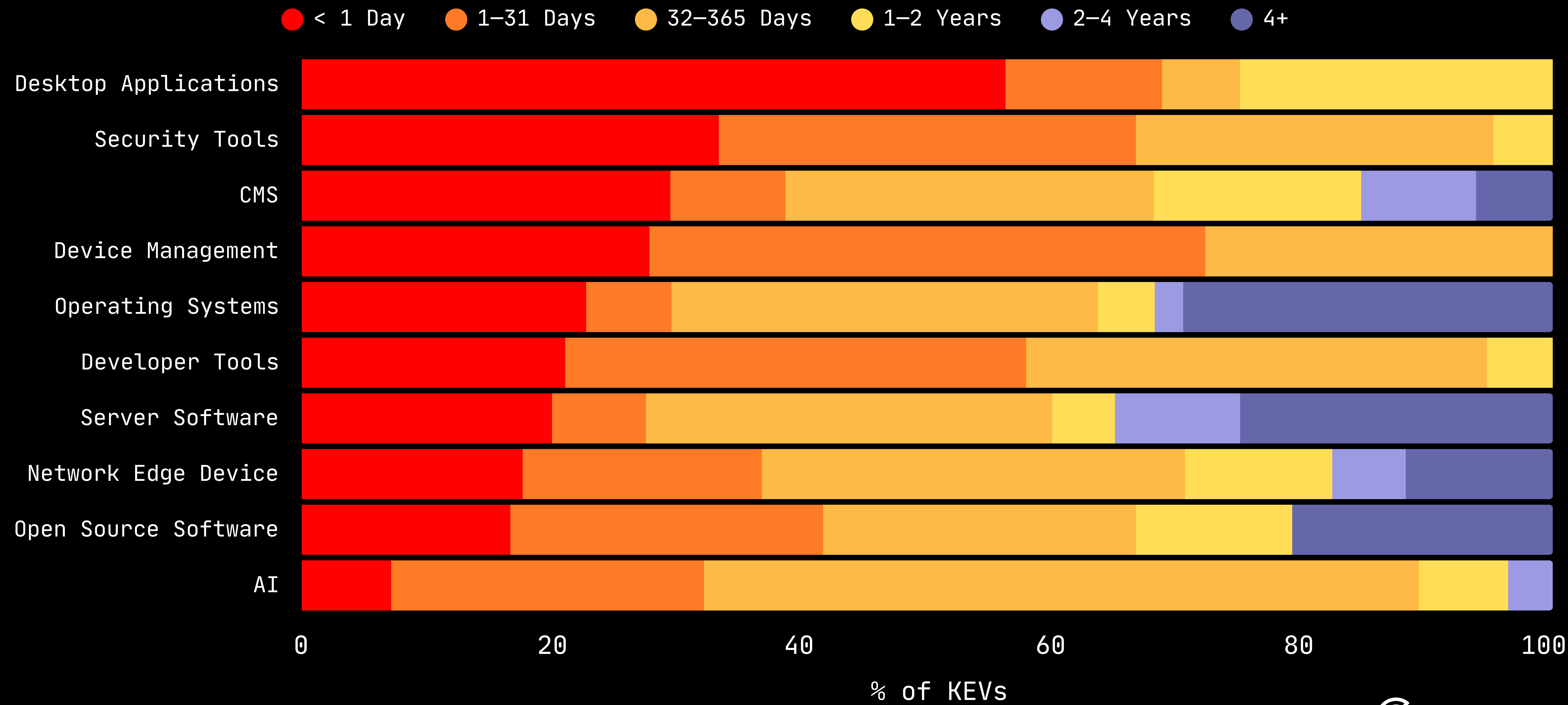
Top Targeted Technologies

Source: VulnCheck KEV
(1H-2026)



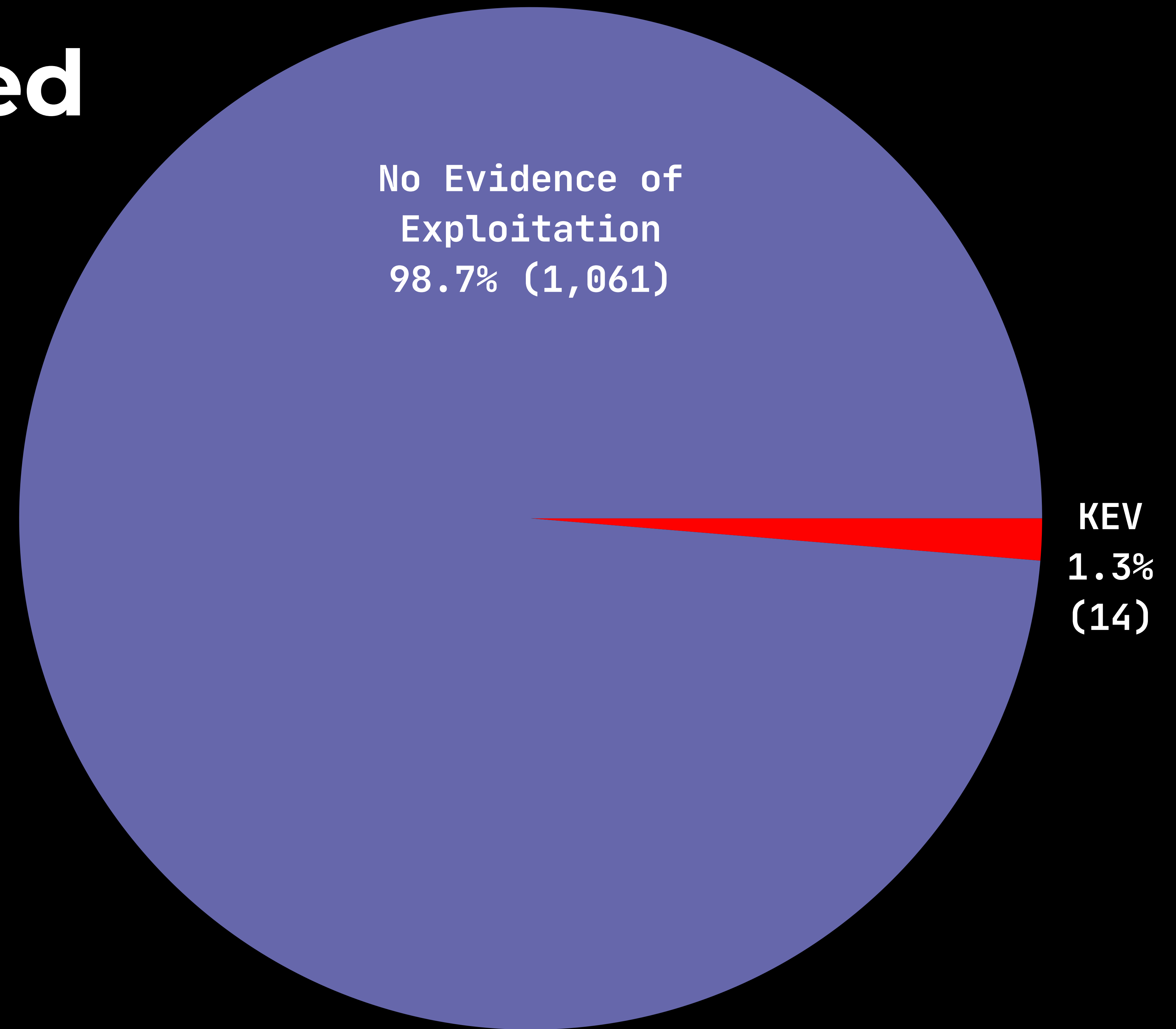
Top 10 Targeted Technologies

Time From CVE to Exploitation Evidence



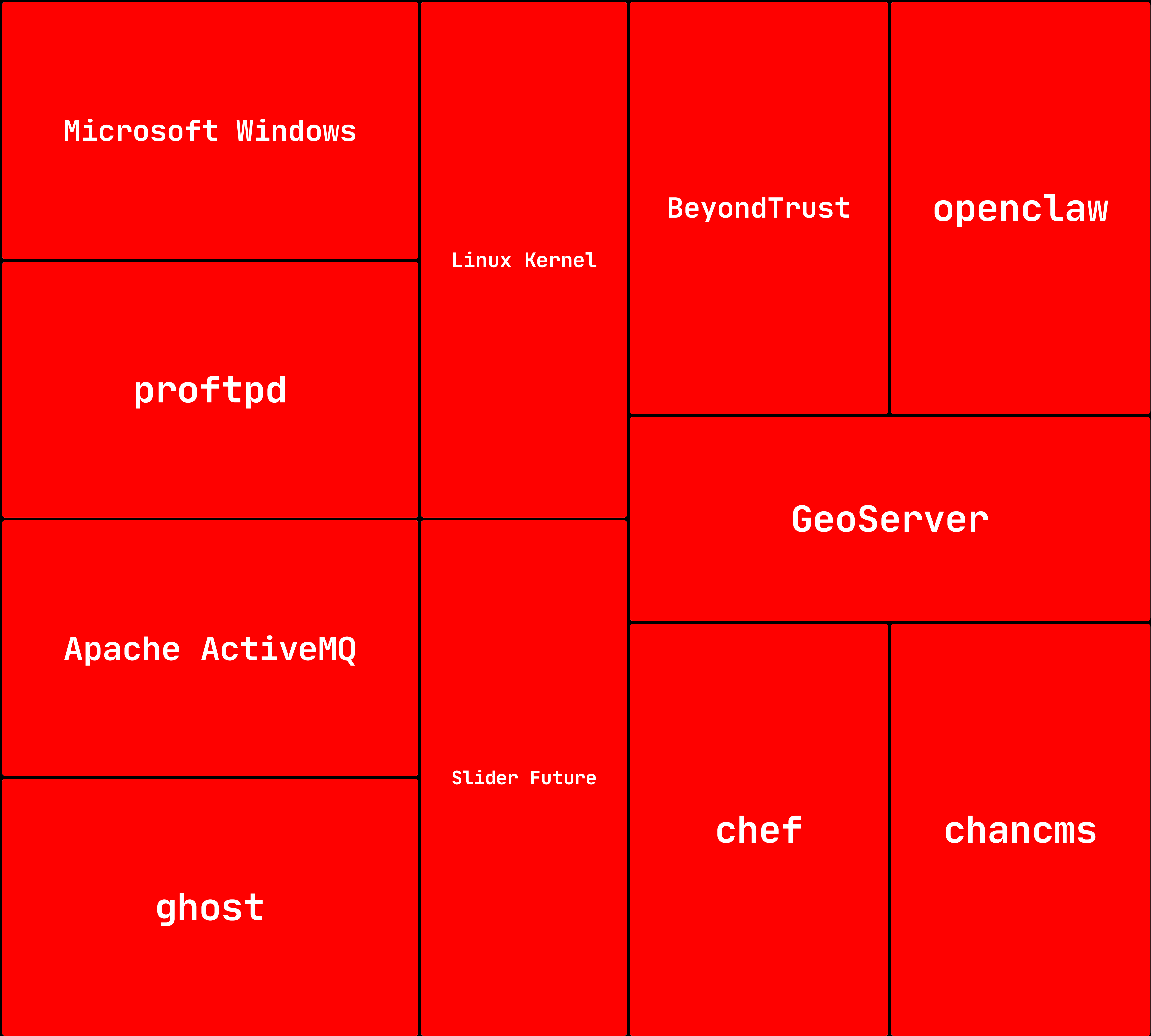
What Percentage of Vulnerabilities Discovered using AI Are Exploited?

1.3% of the 1,061 CVEs
Identified by Berkley
Vulnerability Initiative and
Patrick Garrity's Anthropic
Credited CVEs project are known
to be exploited.



What products were exploited using AI discovered vulnerabilities?

CVEs Identified by Berkley Vulnerability Initiative and Patrick Garrity's Anthropic Credited CVEs project are known to be exploited.



AI Products Exploited In 1H-2026

AI Product							
Langflow				Praison AI	openclaw	Mintplexlabs anythin...	
				Ollama	n8n	MCPJam Inspector	
						lfprojects mlflow	
Majordomo	lollms			internlm lm...	Gradio	comfy	budibase
BerriAI LiteLLM	dify			FlowiseAI		anyscale ray	



Yaara Shriki  · 1st
Threat Researcher @ Wiz
6h · 



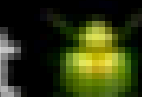
CVE-2026-59821 + **CVE-2026-59822**

I found two vulnerabilities in LiteLLM. Code injection & auth bypass on MCP endpoints.

Oh and we're seeing at [Wiz](#) active exploitation in the wild.
But that's not where the story ends.

I'll be sharing the full story at [DEF CON](#) 

OffGuard: Breaking the Most Popular AI Gateway from Auth Bypass to Cloud Compromise

Saturday at 17:00 in LVCC - L1 - Exhibit Hall West 3 - 903 (Main Track 5)
60 minutes | Demo , Exploit 

Yaara Shriki Wiz (Google)

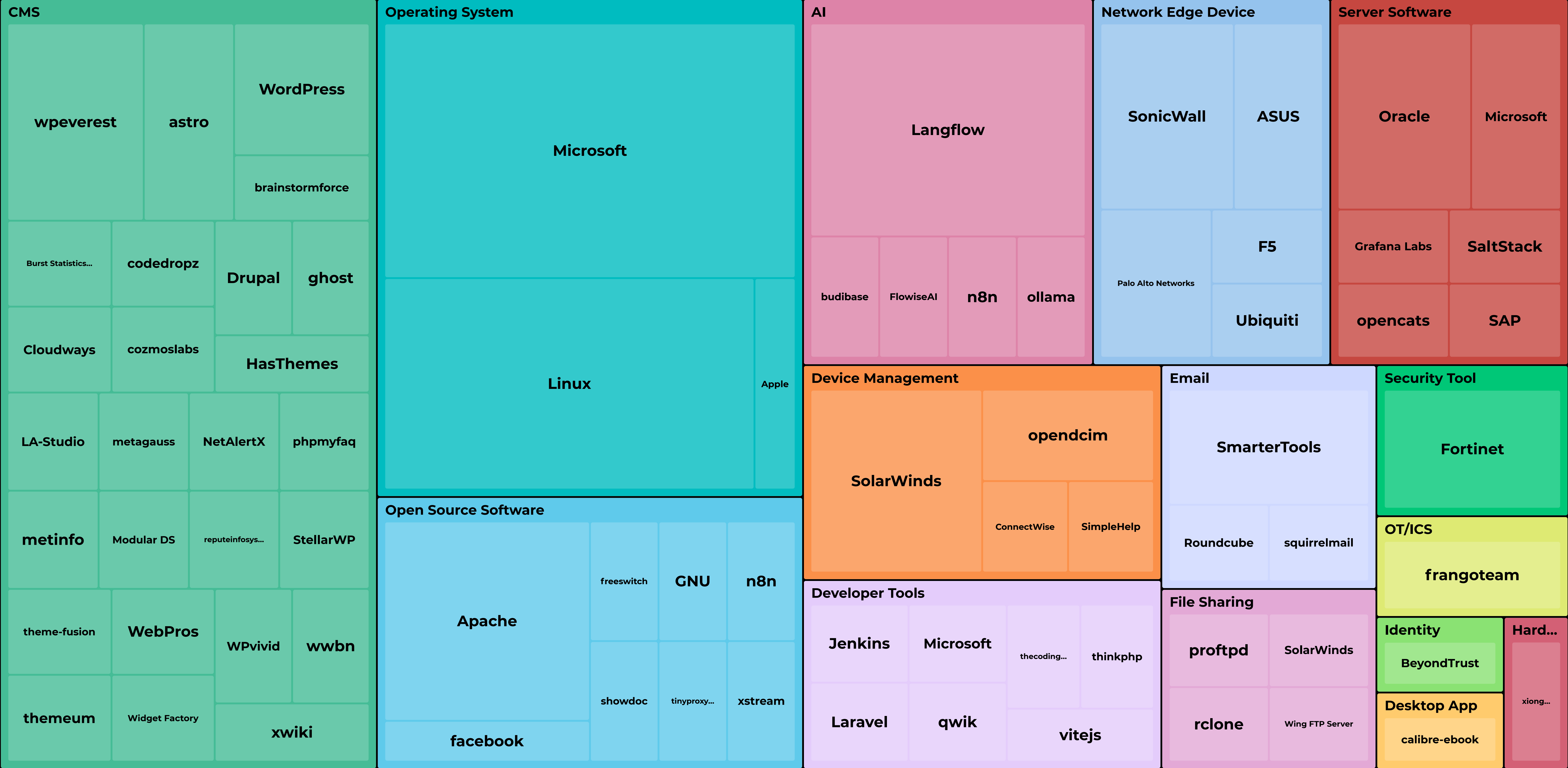
LiteLLM is the most popular open-source AI gateway, deployed across a third of cloud environments. Organizations route all their LLM traffic through it, trusting it with API keys for every provider, every prompt and response, and connections to external tools via MCP. We broke every layer of its security model.

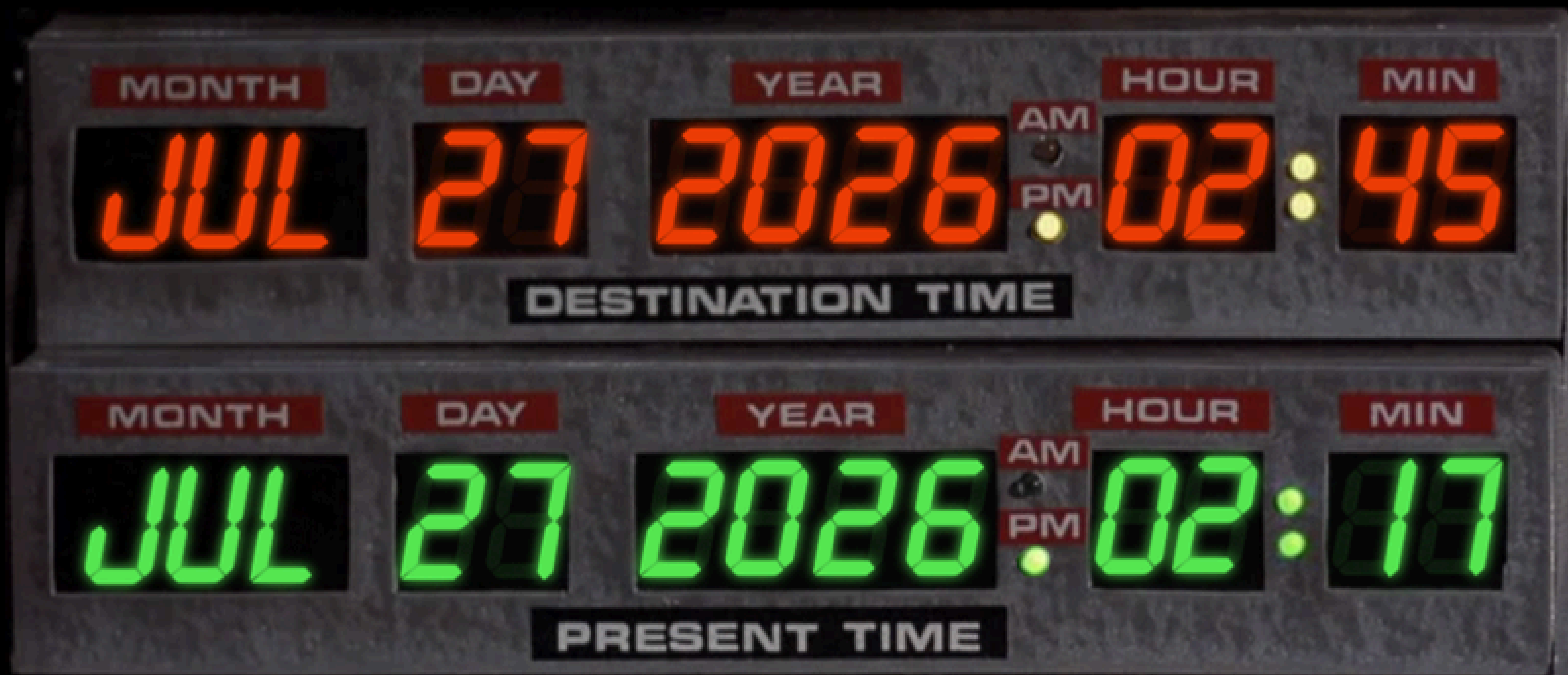
We present three independent attack vectors, an authentication bypass in the MCP layer, a root-level RCE through sandbox escape, and an SSRF path to cloud credentials, that chain from zero credentials to full cloud infrastructure compromise. We validated every attack at internet scale across thousands of real-world instances and found that nearly 1 in 10 accepted default credentials or required no authentication at all.

Beyond the individual findings, we examine the broader security patterns emerging across AI infrastructure and what they mean for organizations adopting AI gateways as core infrastructure.

Internet Exposure by Unique KEV Count

Source: VulnCheck Target Intelligence / 1H-2026 VulnCheck KEV Additions





- 1. The Speed of Exploitation Appears to be Faster**
- 2. The Attack Surface is Growing (Thanks AI!)**
- 3. More Vulnerabilities are being disclosed, but the rate of exploitation isn't growing at the same pace**

Emerging Threat

1. **Rapid Response**
(Generally Faster)
2. **Internet Facing**
3. **End User Interaction**
4. **Remotely Exploitable**

Vulnerability Debt

1. **Root Cause Analysis**
2. **Improve Patch Management**
3. **Implement Best Practices**
4. **Prune Unused / EOL**
5. **Protect The New AI Attack Surface!**

Questions?



Patrick Garrity

SECURITY RESEARCHER

Follow My Work

